

TraceNex Partner — 产品需求文档 (PRD)

版本: **v1.0** (2026-05-09, 基于 v0.2 + 4 agent Round-2 review 收敛而成) 仓

库: `/Users/nathan/Projects/apiGateway/TraceNexBiz/` 上游需

求: `/Users/nathan/Projects/apiGateway/needs/大模型融合平台-渠道分销系统需求文档.docx`

(v1.2, 2026-04-20) 关联系统: `Fy-api` (AI 网关层, 详见

`/Users/nathan/Projects/apiGateway/Fy-api/`) 维护人: Nathan

v1.0 状态: 四方 Round-2 review 全部通过: – PM: ACCEPT_WITH_NOTES (0 CRITICAL / 3 HIGH) – Architect: ACCEPT_WITH_NOTES (0 CRITICAL / 3 HIGH) – Security: ACCEPT_AS_V1.0 (0 CRITICAL / 3 HIGH) – Compliance: ACCEPT_WITH_NOTES (0 BLOCK_LAUNCH / 3 PRE_LAUNCH)

全部 reviewer 一致: 升级到 v1.0、Phase 1 立即开工。本版本相对 v0.2 合入了 reviewer 要求的 mechanical diffs (详见 §21 v1.0 CHANGELOG)。剩余 HIGH / PRE_LAUNCH 作为 Phase 1 实施期跟踪项收纳到 §22 “v1.0 → Phase 1 follow-ups”, 不再触发 PRD 迭代。

v0.2 关键变更 (相对 v0.1, 保留作为审阅追溯): – **● BLOCK-合规:** 去除“二清”——资金流改为**持牌分账方托管模式**; `partner_wallet` 重新定义为“应付台账负债”, 不再沉淀客户付款 (§7.6 / §8.3 / §9 / §15) – **● BLOCK-合规:** 去除“不做内容审核”——新增 §7.12 内容安全 (输入+输出双层 guardrail, 模型上架白名单) – **● BLOCK-合规:** 新增 §15 Compliance & License Plan (ICP 经营许可证、生成式 AI 备案、等保 2.0、PIA、CAC 标准合同、个人渠道商代扣代缴) – **● CRITICAL-架构:** 撤回“Fy-api 不动一行代码”——新增附录 C 描述必须的 Fy-api 覆盖层 (约 200-300 LOC, 10 个文件, 监控期内可吸收的成本) – **● CRITICAL-架构:** 撤回 CDC 推荐——改为**应用层 outbox 模式** (DB-portable, 不绑死 MySQL; 详见 §9.3) – **● CRITICAL-架构:** 撤回“调价立刻生效”——通过 **Redis Pub/Sub 失效缓存**, 承诺 < 2 秒传播 (§9.2) – **● CRITICAL-架构:** 将 group 模型从 per-customer 改为 **per-tier** (每渠道商 1-N 档), 并支持 `User.GroupRatioOverride` (§9.2 / §C-2) – **● CRITICAL-架构:** BIGINT 升级 `User.Quota` / `Log.Id` / `Log.Quota` (§C-2 / 附录 C) – **● CRITICAL-安全:** 新增 §16 威胁模型 (STRIDE)、§17 鉴权与会话、§18 幂等契约、§19 密钥管理; 钱包/扣额度/退款全 endpoint 强制 `Idempetency-Key` – **● CRITICAL-安全:** `partner_wallet` 增 `wallet_hold` 表 (两阶段提交 / 真正可见的“已锁定余额”) – **● CRITICAL-安全:** 审计日志改为**追加只写 + 哈希链** (§8.13 / §H-2) – **● CRITICAL-PM:** Phase 1 honest re-scope——钱包从第一天就用 (即使初始余额由平台预拨); 不“绕过钱包” (§12.1) – **● CRITICAL-PM:** 新增 §1.4 成功度量 (KPI / 退出条件); 废除“特性清单 = 上线”框架 – **● CRITICAL-PM:** 新增场景 H-O (流失、迁移、退款、争议、KYC 驳回、直营、合并、跨期入驻、零余额) 于 §4 – **● CRITICAL-PM:** 定价模型从单标量 markup 升级为 `partner_pricing_rule (model? + tier? + valid_from + valid_to + markup)` – **● CRITICAL-PM:** 新增 §14 状态机 (partner / customer / settlement / KYC / dispute / saga) – **● HIGH 已处理:** 权限矩阵 §3.4; 客户体验 / 防绕过 §7.9; 客服/工单 §7.10; 通知模块 §7.11; 附录 D 术语表 – **MEDIUM** 收纳到 §13 和 §11, 未在 v0.2 必修, 标注计划处理时点

状态: v0.2 → 4 agent Round-2 review → 收敛到 v1.0 (本版本)。

0. 目录

1. 产品定位
 2. 关键决策（已拍板）
 3. 用户角色 + 权限矩阵
 4. 业务场景（含流失 / 迁移 / 异常路径）
 5. 系统架构
 6. 与 Fy-api 集成边界
 7. 功能需求（按模块）
 8. 数据模型
 9. 计费链路设计
 10. 非功能性需求
 11. 风险与对策
 12. 里程碑
 13. 待业务进一步确认的问题
 14. 状态机
 15. 合规与资质计划（NEW，BLOCK 级）
 16. 威胁模型（NEW）
 17. 鉴权与会话（NEW）
 18. 幂等契约（NEW）
 19. 密钥管理（NEW）
 20. 术语表
 - 附录 A 隐私政策草案大纲
 - 附录 B 用户协议 / 渠道商合作协议要点
 - 附录 C Fy-api 覆盖层（overlay）清单
 - 附录 D 术语表
-

1. 产品定位

TraceNex Partner 是一个渠道分销 SaaS，作为独立产品运行在 TraceNex 现有 AI 网关（Fy-api）之上。

1.1 核心价值

- 让渠道商在 TraceNex 上发展自己的客户、自主定价加价销售、收取分润
- 让终端客户通过渠道商入驻，获得统一的 AI 网关访问能力
- 让平台方（TraceNex 运营方）通过渠道商体系扩展销售半径，节省直销成本

1.2 一句话定义

“把 TraceNex 这个 toC/toB 直销 AI 网关，扩展为支持二级分销代理的合规 SaaS 平台。”

1.3 不做什么（Out of Scope）

- **✗** 不重写 AI 网关——所有计费 / 路由 / Token 管理仍走 Fy-api
- **✗** 不做多级（≥3）分销——本期只做二级（平台 → 渠道商 → 终端客户）
- **✗** 不做“招标式比价”或“模型聚合调度优化”——这些是 Fy-api 的核心能力
- **✗** 不沉淀客户备付金——所有支付通过持牌分账方（§7.6 / §15）

v0.1 中“不做 LLM 内容审核”这条已删除：作为生成式 AI 服务提供者（《生成式人工智能服务管理暂行办法》第 4、9、14、17 条），TraceNex 必须做内容安全合规。详见 §7.12 + §15。

1.4 成功度量（NEW）

以下指标决定每个 Phase 的“完成”，**必须在每周复盘时跟踪**。Feature 检查清单不再作为上线判据。

Phase 1（MVP / 内测）退出条件

指标	目标	测量
接入种子渠道商数	≥ 5 家	后台 partner 计数
每家渠道商有效客户数	≥ 2 家有 ≥ 2 客户	跨表查询
累计平台 GMV（含直营 + 渠道）	≥ ¥10,000	revenue_log SUM
钱包对账漂移事件	= 0	每日对账 Job 输出
关键工单平均响应	≤ 24h	ticketing 系统

Phase 2（商业化）退出条件

指标	目标
KYC 一次通过率	≥ 70%
KYC 决策 P95 时延	≤ 24h
渠道商激活率（申请 → 首笔分润）	≥ 60%
30 日渠道商留存	≥ 80%
平均有效 markup（按 GMV 加权）	业务回填基线
月结按时支付率	≥ 99%
客户流失率（渠道下）	< 10% / 月

Phase 3（企业级）退出条件

指标	目标
发票申请响应 P95	≤ 5 工作日
席位续费率	≥ 70%
客户从首次充值到首次出账的成功率	≥ 95%

全期持续指标

- 单次接口越权事件 = 0（每月一次随机渗透 + CI 越权测试 100% 覆盖）
- PII 泄露事件 = 0
- 备案 / 资质过期事件 = 0
- 合规整改事项关闭 SLA：CRITICAL 7 日，HIGH 30 日

2. 关键决策（已拍板）

决策项	选择	备注
仓库目录	/Users/nathan/Projects/apiGateway/TraceNexBiz/	与 Fy-api 平级
产品名	TraceNex Partner	品牌延续
后端技术栈	Go (Gin + GORM v2)	与 Fy-api 同栈
前端技术栈	React 18 + Vite + Semi UI	与 Fy-api/classic 一致
数据库边界	同实例不同库（推荐方案，详见 §6.3）	但 LOG_DB 可分离，参见 §5.2 / §6.3
结算周期	可配置（默认月结）；切换走 §14 状态机	切换审计 + 不影响在途
第一批渠道商	招商优先 + 自助入驻并行	双流程，PRD 里都设计
MVP 时间线	10–12 周完整商业化上线（合规轨平行启动）	三期
资金清算	🔴 持牌分账方托管（连连支付 / 易宝 / 汇付 / 合利宝 等候选）	参见 §15 / §7.6
数据库方言兼容	必须兼容 Fy-api 的 MySQL/PG/SQLite 三种	不允许引入 MySQL-only 工具如 canal
Fy-api 覆盖层	接受约 200–300 LOC 增量，纳入 OVERLAY.md 跟踪	详见附录 C
PII KMS	Aliyun KMS（与 Fy-api 同生态）+ 信封加密	详见 §19
会话与鉴权	复用 Fy-api JWT + WebAuthn（staff 强制） / TOTP（partner 强制）	详见 §17

3. 用户角色 + 权限矩阵

3.1 顶层角色



法律身份脚注 (v1.0 合规): 渠道商对其客户而言是《电子商务法》§9 意义上的”平台内经营者”, TraceNex 作为平台运营者承担 §27 (资质审核) + §38 (连带责任)。详见 §15.8。

3.2 平台 staff 子角色 (§8.14)

子角色	职责
super_admin	全权限, 含 staff 管理
operations	渠道商 / 模型 / 公告 / 工单的运营动作
finance	充值 / 退款 / 月结审批 / 发票
support	工单回复 / 限额内退款 (≤ ¥500)
system (隐式)	Cron / Outbox / Saga retry, 不能登录

3.3 渠道商 / 客户多座位 (v1.x)

v1.0 单座位: 一个 partner 行 = 一个 Fy-api User。v1.x 计划: `partner_member(partner_id, fy_user_id, role, scopes)`, `role` ∈ {owner, finance, ops, viewer}。客户侧类似 `customer_member`。本期显式 out-of-scope, 但 schema 预留 `partner.id` FK 不变。

3.4 权限矩阵 (v1.0 必交付)

行: 动作 (verb), 列: 角色。✅ 允许 / ⚠️ 限额 / ❌ 禁止 / A elevated (强制审计)

动作	super_admin	operations	finance	support	partner	customer
partner.create	✅	✅	❌	❌	❌	❌
partner.approve_kyc	✅	✅	❌	❌	❌	❌
partner.suspend	✅	✅	❌	❌	❌	❌
partner.terminate	✅	❌	❌	❌	❌	❌
wallet.adjust (任意)	✅	❌	✅	❌	❌	❌
wallet.refund	✅	❌	✅	⚠️ ≤¥500	❌	❌
customer.list_all	A	A	A	A	❌	❌
customer.list_own	✅	✅	✅	✅	✅	❌
customer.read	A	A	A	A	✅(自家)	✅(自己)
customer.allocate_quota	✅	❌	❌	❌	✅(自家)	❌
customer.disable	A	A	❌	❌	✅(自家)	❌
pricing.set	✅	❌	❌	❌	✅(自家)	❌
pricing.read_wholesale	✅	✅	✅	❌	✅(自家 P0)	❌
settlement.generate	✅	❌	✅	❌	❌	❌
settlement.mark_paid	✅	❌	✅	❌	❌	❌
kyc.review	✅	✅	❌	❌	❌	❌
kyc.export_pii	A	❌	A	❌	❌	❌
invoice.issue	✅	❌	✅	❌	❌	❌
audit_log.read	✅	✅	✅	✅	✅(自家)	✅(自己)
staff.create	✅	❌	❌	❌	❌	❌
system.config_write	✅	❌	❌	❌	❌	❌

实现: `middleware/scope.go` + `middleware/permission.go`, 每条动作有 enum; 越权拒绝返回 404 而非 403 (不泄露存在性, §16)。CI 必须有 "matrix BOLA test" 覆盖每条 row × column。

4. 业务场景（关键 User Journey）

4.1 场景 A：渠道商招商入驻（人工招商流）— happy path

平台运营 → 沟通获客 → 渠道商联系平台 → 平台 staff 在管理后台创建渠道商账号（含初始钱包余额、默认 markup tier、专属邀请码）→ 渠道商收到激活邮件 → 登录后台 → 完成 KYC → 开始拉客户。

4.2 场景 B：渠道商自助入驻（线上自助流）— happy path

注册 TraceNex 账号 → 个人后台「申请成为渠道商」→ 选择「企业 / 个人」→ **单独同意**生物识别采集（§4.10）→ 上传认证资料 → 提交审核 → 平台审核（24h SLA）→ 通过/驳回 → 通过后获得渠道商权限 + 默认 markup tier + 邀请码。

4.3 场景 C：终端客户被邀请入驻

渠道商生成邀请码（或邀请链接）→ 客户点击链接注册 → 自动绑定渠道商 → 客户后台显示“由 X 提供服务”（§7.9 强制）→ 客户调 API → 计费按渠道商加价 → 同步记 `revenue_log`（异步 outbox 消费）。

4.4 场景 D：渠道商充值客户

客户余额不足 → 渠道商在自己后台找到客户 → 点击「充值」→ 输入金额 → 提交（带 `Idempotency-Key`）→ §9.4 saga: 1. **Hold** 渠道商钱包 -X（写入 `wallet_hold`，状态 `held`）2. 调 Fy-api `POST /api/internal/user/topup`（带相同 `idem-key`）+X 给客户 3. Fy-api 成功 → `wallet_hold.status = committed`，`partner_wallet.balance` 真实减 X，写 `partner_wallet_log` 4. Fy-api 失败/超时 → 调 `GET /api/internal/topup/by-idem-key` 探活；明确未生效则 `wallet_hold.status = released`；明确已生效则按 3 收尾

UI 层：渠道商可见「可用余额 = $\text{balance} - \text{sum}(\text{held})$ 」。

4.5 场景 E：客户调 API 计费

客户调 `/v1/chat/completions` → Fy-api 路由上游 → 计费走 Fy-api 现有 `group_ratio` 链路（用 **per-tier group**，§9.2）→ 扣 `User.quota` → 写 `logs` + 同事务写 `consume_log_outbox`（覆盖层提供）→ TraceNexBiz outbox poller 消费 → 写 `revenue_log`（`fy_api_log_id` UNIQUE）。

4.6 场景 F：月度结算

每月 1 号 UTC+8 02:30（Cron，时区固定，`biz_setting.timezone`）→ K8s Lease 锁 → 状态机 `generating` → `generated` → `paying` → `paid`。 - 计算上月每个渠道商的：`Gross = SUM(revenue_log.gross)`、`Cost = SUM(...cost)`、`Withheld = WithheldTaxFor(partner)`、`Payout = (Gross - Cost - Withheld) - PlatformFee` - 通过持牌分账方下达分账指令（§7.6） - 失败 / 部分成功支持续跑（`settlement.progress_offset`，§14）

4.7 场景 G：发票申请

客户/渠道商申请 → 提交抬头 + 税号 → 财务审核 → 通过则走”全电发票”系统开票 (v1.x 人工对接) → 推送电子发票 → 邮件抄送。

4.8 场景 H (NEW)：客户切换渠道商

客户主动申请「转挂到渠道商 B」→ 通知**双方渠道商**确认 (partner A 确认放行, partner B 确认接收) → 平台 staff 终审 → 切换: - 该客户当月已发生的 `revenue_log` 冻结归 A 结算 - 新 `User.group` 切换至 partner B 的对应 tier; 切换时点写 `customer_partner_change_log` - partner A 的 KYC / 数据访问权限对该客户立即终止 - 客户钱包余额 / 已购席位 **不变** (属于客户)

实现: `POST /api/customer/transfer` (idempotent), 三方 `acceptance_state machine`。

4.9 场景 I (NEW)：渠道商终止 / 暂停

触发: 渠道商主动退出 / 平台合规处置 / KYC 复审驳回。

1. partner 状态 → `suspended` (KPI/合规处置) 或 `terminated` (永久)
2. 在途未结算 `revenue_log` 立即冻结 (`settlement.preflight` 跳过该 partner)
3. 该 partner 的客户: 默认转入”平台直营托管池” (`customer.partner_id = NULL` , `customer.transferred_from`), 客户的 API Key 保持有效 30 天宽限期; 30 天后必须主动选新渠道或维持直营
4. partner 钱包余额: 扣除应付未付的客户欠款 → 剩余正数解冻 30 天后退还 (保留追偿权)
5. 已签 `kyc_application` 进入冷归档 (5 年保存, §15)

4.10 场景 J (NEW)：客户退款 + revenue 反向

退款类型 × 时点 × 影响:

类型	在结算前	已结算未支付	已支付 (→ 渠道商已收钱)
客户主动 7 日内	<code>revenue_log</code> 写补偿 (负数) + 还原客户额度	同左 + 标记 <code>settlement_item dispute</code>	partner 留出 hold; 下个结算扣回
平台风控强制	同左	同左	平台公告 + partner 协议追偿
计费错误 (双方共担)	同左, 无 partner 责任	同左	平台账户单方追偿, 不影响 partner 信用

`refund` 必有审计 + idempotency key, **绝不**直接物理删除 `revenue_log`。

4.11 场景 K (NEW)：账单争议端到端

客户在账单中心点「我有疑问」→ 创建 `billing_dispute` (关联 `revenue_log`) → partner 仪表盘出现 dispute → partner 1 个工作日内回应 → 升级至 staff 仲裁 → 维持/翻案 → 翻案则触发 §4.10 退款流 (「计费错误」类型)。

4.12 场景 L (NEW): KYC 驳回 + 重审

驳回理由分类 (≥ 5 类): 照片不清晰 / OCR 信息不一致 / 法人非本人 / 资质过期 / 主体重复。客户可直接重提。每自然年最多 3 次驳回; 超过冻结, 需要走 staff 工单上诉。

4.13 场景 M (NEW): 客户直接 (无邀请码) 注册

客户走公开注册 → `customer.partner_id = NULL` (直营客户) → 永远不进入渠道商分润视野。

4.14 场景 N (NEW): 被邀请的客户已是直营用户

`POST /api/internal/user/check-by-email` 返回已存在 → 提示客户「您已是直营客户。是否申请挂靠到 X」 → 客户同意 + 平台审核 (防止“挖墙脚”, §13 Q9) → 转挂。不允许自动 silent 转挂。

4.15 场景 O (NEW): 渠道商跨期入驻

partner 在月中 (如 5/15) 通过审核 → 第一个 settlement period 是 6 月初 (仅结 5/15–5/31 数据) → `settlement_item.is_partial = true` + 备注。

4.16 场景 P (NEW): 客户余额清零

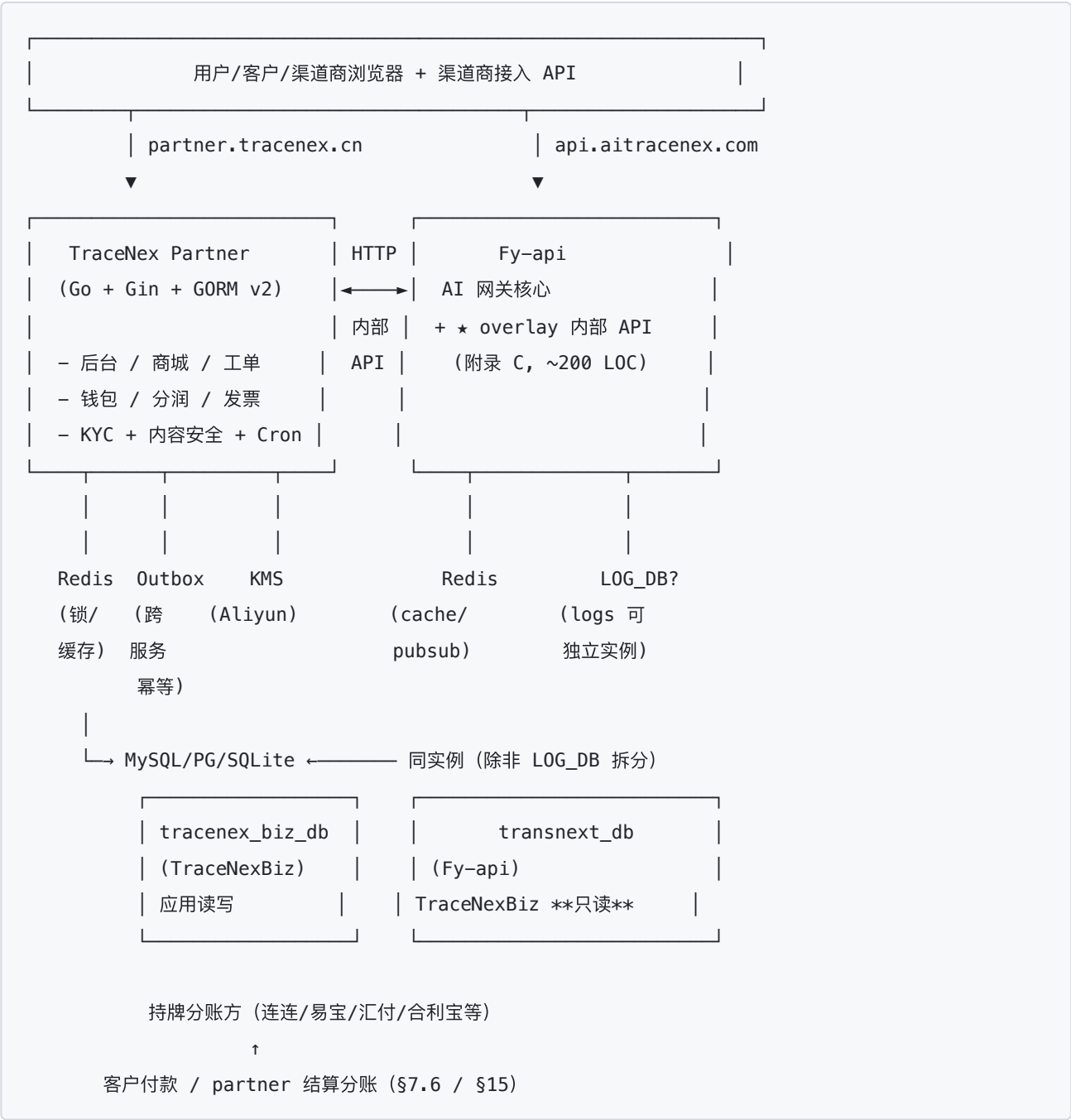
客户用量耗尽 → Fy-api 返回 402 Insufficient Quota → TraceNexBiz `consume_log_outbox` 检测 + 触发: - 邮件通知客户 + 渠道商 - 客户后台显示「余额已用尽, 请联系您的渠道商: X 接洽人 / 邮箱 / 工单按钮」 - 自动屏蔽“上线模型菜单”, 避免 UI 误导

4.17 场景 Q (NEW): 右遗忘 (PIPL Article 47)

客户行使删除权 → 平台核身 → 触发: - `customer.deleted_at` 软删除 - KYC 原始资料: `PiiPurgedAt = NOW()`, OSS 私有 URL 失效; 冷归档保留 5 年 (§7.7 / §15) - `audit_log_pii` 中相关条目 tombstoned; `audit_log` 主表保留 (含哈希链) - `revenue_log` 不删——脱敏 `fy_user_id` 为“已删除用户”占位 (保结算可重算) - Fy-api 触发 `POST /api/internal/user/erase` 软删 user

5. 系统架构

5.1 总体两层 + Redis + 日志



5.2 关键设计原则（更新）

1. TraceNex Partner 不持有 Fy-api 表的写权限——users / tokens / logs 表只读；写入通过 §6.1 内部 API。通过 MySQL 用户授权强制 (§6.3)。
2. TraceNex Partner 持有的业务表自治——所有 partner / customer / wallet / pricing / revenue / settlement / kyc / invoice 等业务表完全在 tracenex_biz_db。

3. **跨库 join 仅在报表场景**，前提：日志库 `transnext_db.logs` 与业务库在**同一实例**。若 `LOG_SQL_DSN` 把日志拆出来（SG 现有部分集群已经如此），TraceNexBiz 报表层 fallback 到 **HTTP API + 应用层聚合** (§6.3 增加双路径)。
 4. **资金事务全在 TraceNexBiz 侧 + Saga**——钱包扣减 + 客户额度增加是分布式事务 (§9.4)，永远不沉淀客户付款 (§7.6)。
 5. **永远不依赖 binlog**：MySQL 专属工具不被允许（兼容 PG/SQLite）；通过应用层 outbox 解决 (§9.3)。
 6. **Fy-api 覆盖层需求**：约 200–300 LOC，新文件为主，纳入 `Fy-api/OVERLAY.md`，月度上游同步 ritual 已经能吸收（附录 C）。
-

6. 与 Fy-api 集成边界

6.1 Fy-api 提供给 TraceNex Partner 的内部 API (/api/internal/*)

这些 API 目前不存在——是 Fy-api 覆盖层（附录 C）的一部分，必须在 Phase 1 就上。

接口	用途	幂等键	调用方
POST /api/internal/user/create	创建客户/渠道商账号	Idempotency-Key 必传	Partner
POST /api/internal/user/topup	给指定 user 加额度	必	Partner
POST /api/internal/user/deduct	给指定 user 扣额度（异常修正）	必	Partner
POST /api/internal/token/create	给 user 创建 API Token	必	Partner
PUT /api/internal/user/group	修改 user.group	必	Partner
PUT /api/internal/user/group_ratio_override	设置 user.GroupRatioOverride（覆盖层新加字段）	必	Partner
GET /api/internal/usage/by-user?from=&to=	查询某 user 用量	—	Partner
GET /api/internal/usage/by-group?group=&from=&to=	查询某 group 总用量	—	Partner
POST /api/internal/group	创建/更新自定义 group_ratio	必	Partner
GET /api/internal/topup/by-idem-key?key=	崩溃恢复：查询某 idem-key 实际状态（仅原始提交者的 X-Auth-KeyId 可调用）	—	Partner
GET /api/internal/group/by-idem-key?key=	同上（group 操作）	—	Partner
POST /api/internal/user/erase	PIPL 47 删除	必	Partner

鉴权（修订 §17）

不是简单的”static API key + HMAC”。具体如下（参考 AWS SigV4，Stripe-Connect-MFA 模式）：

- HTTP header X-Auth-KeyId（key 标识，支持 N+1 滚动）
- HTTP header X-Auth-Timestamp（RFC3339，±300 秒窗口）
- HTTP header X-Auth-Nonce（UUIDv4，服务端 Redis SETNX dedup 5 分钟）

- HTTP header `X-Signature` = `HMAC-SHA256(secret, "POST\n/api/internal/user/topup\nq=...\n${ts}\n${nonce}\n${sha256(body)}")` (base64)
- 内网 mTLS (K8s Service-to-Service mTLS 或 sidecar) —— **强制要求**, 明文 HTTP 一律拒收
- key 绑定 service-account (CDC consumer 与 Topup writer 不同 key), 各自有 endpoint allowlist

6.2 TraceNex Partner 反向通知 Fy-api

无同步反向; 通过 outbox (§9.3) 异步消费 Fy-api 写入的 `logs`。

6.3 数据库边界 (修订)

双层强制:

1. **MySQL 用户级:** TraceNexBiz 应用使用 user `tnbiz_app@%` (GRANT SELECT/INSERT/UPDATE/DELETE on `tracenex_biz_db.*`, 仅 SELECT on `transnext_db.*`)。Schema 迁移使用独立 user `tnbiz_migrator@%`。永远不给应用 user 写权限到 `transnext_db`。CI 部署 gate 检查 `SHOW GRANTS`。
2. **GORM 双 connection:** `bizDB` (read-write `biz_db`) 和 `fyDB` (read-only `transnext_db`); 后者所有 query 走 `Session(&gorm.Session{...QueryFields: true})` 标识 query。

LOG_DB 拆分场景: 当 Fy-api 配置 `LOG_SQL_DSN` 指向独立实例时, 跨库 JOIN 不可用。– 短期: 报表 fallback 到 §6.1 的 `GET /api/internal/usage/*` HTTP API – 长期: 独立 ETL 同步到 OLAP 数据库

v0.2 决策: 报表层代码必须两条路径都写 (DB JOIN 优先, HTTP API 备选), 由配置开关切换。

6.4 用户身份映射

Fy-api User 视角	TraceNexBiz 视角
<code>User</code> (普通账号)	<code>customer</code> / <code>partner</code> / 直营 (无 TraceNexBiz 行)
<code>User.id</code>	在 <code>customer.fy_user_id</code> 或 <code>partner.fy_user_id</code> 引用
<code>User.group</code>	决定计费倍率; TraceNexBiz 写入受限 (覆盖层 API)
<code>User.GroupRatioOverride</code> (NEW)	渠道商私有定价的细粒度 hook (覆盖层加字段)

身份升级 / 降级: – 升级: 客户 → 申请成为渠道商 → 审核通过 → `partner` 行 + 邀请码 + Fy-api group 移到 `partner` 自家 tier – 降级 (terminated): 见场景 I

7. 功能需求

编号沿用上游需求文档 (§3.x)，优先级 **P0 必做 / P1 重要 / P2 增强**。★ 标记为”涉及 Fy-api 覆盖层”。

7.1 模块一：公开商城 / 招商落地页

ID	功能	优先级	实现要点	★
M1-01	模型展示	P0	复用 Fy-api <code>/api/pricing</code> ；只展示已通过备案的模型（白名单）	★
M1-02	模型详情页	P0	单独路由；显示能力 / 定价 / 调用示例 + 服务声明 （生成式 AI 风险提示）	
M1-03	模型对比	P1	多选模型对比	
M1-04	用户注册/登录	P0	复用 Fy-api <code>/api/user/register</code> ；邀请码注册需原子绑定	★
M1-05	申请成为渠道商落地页	P0	静态营销页	
M1-06	渠道商申请表单	P0	分企业/个人 tab；含 两层勾选 （用户协议 + 单独同意敏感 PI）	★
M1-07	在线购买（订阅 + 按量）	P0	复用 Fy-api <code>/api/subscription/plan</code> ，支付走持牌分账 (§7.6)	★
M1-08	试用额度	P1	\$0.50 quota； 配 IP / 设备指纹防刷	★
M1-09	多语言	P1	i18next；中/英两版隐私政策	

7.2 模块二：终端客户后台

ID	功能	优先级	实现要点	★
M2-01	仪表盘	P0	复用 Fy-api /api/user/dashboard ; 显示 outbox 数据”截至 HH:MM:SS”	★
M2-02	余额查询	P0	显示 + “由 X 渠道商提供” (§7.9)	★
M2-03	充值（持牌分 账方收单）	P0	§7.6 重写：客户付款 → 持牌 分账方 → 平台分账主体 + 渠 道商主体	★
M2-04	充值（线下转 账）	P0	用户上传银行回单 → 平台审 核 → 调 Fy-api 加额度	★
M2-05	API Key 管理	P0	复用 Fy-api /api/token ; partner 不 可见客户 API Key 明文	★
M2-06	席位管理	P0	TraceNexBiz seat ; 席位 绑 Token	★
M2-07	模型配置	P0	复用 Fy-api /api/user/models ; 申 请开通走 §7.10 工单流	★
M2-08	账单中心	P0	跨库 join 或 HTTP API (§6.3)	★
M2-09	CSV/PDF 导 出	P0	复用 Fy-api CSV (d60e0eed0) + Go maroto 库出 PDF	★
M2-10	发票申请	P0 (升级)	§7.8 改 P0	
M2-11	角色切换（客 户/渠道商）	P0	单登录 + 顶部下拉；同账号 是 partner + 别家 customer 不允许（避免左右手交易）	
M2-12	认证中心	P0	§7.7 KYC + §15 单独同意	
M2-13 (NEW)	余额预警 + 零 余额体验（场 景 P）	P0	< 20% 余额：邮件 + 站内 信；= 0：模型菜单灰；提供” 联系渠道商”按钮	
M2-14 (NEW)	工单 / 客服	P0	§7.10	
M2-15 (NEW)	通知中心	P1	§7.11	

7.3 模块三：渠道商后台

核心增量模块，全部 P0。

ID	功能	优先级	实现要点
M3-01	渠道商仪表盘	P0	实时聚合 <code>revenue_log</code> + <code>customer</code> ; 显示数据”截至 HH:MM:SS”
M3-02	邀请客户	P0	<code>invitation_code</code> (≥ 16 字符高熵); 5 次/IP/h 限速; 状态机
M3-03	客户列表 + 详情	P0	越权严控; 客户 API Key 永不可见
M3-04	客户额度分配	P0	§9.4 saga + idempotency; 永远走 <code>wallet hold</code> (不绕过)
M3-05	客户充值 (手动 / 替客户线下转账)	P0	同上
M3-06	客户 License 分配 (席位)	P0	<code>seat.partner_id</code>
M3-07	移除/禁用客户	P0 (升级)	软删除 + Fy-api 调用; 调用前再次 status check (TOCTOU)
M3-08	加价销售	P0	新模型: <code>partner_pricing_rule(partner_id, model?, tier?, valid_from, valid_to, markup)</code> ; 详见 §9.2
M3-09	渠道商钱包 (应付台账)	P0	§7.6 / §8.3 重写; 钱包余额 = 平台应付给渠道商的负债 (来自分润), 不是客户充值的钱
M3-10	消费账单	P0	渠道商角度: 自己的收入 / 成本 / 分润
M3-11	客户额度上限设置	P1	渠道商在客户详情页设置
M3-12	批发价透明	P0 (升级)	以便渠道商定价; 只读视图
M3-13 (NEW)	markup 上下限 + 历史价	P0	服务端校验 $1.0 \leq \text{markup} \leq \text{MaxMarkup}$ (业务可配, 默认 5.0); 展示历史 markup 时间线
M3-14 (NEW)	客户切换出/入 (场景 H)	P1	双方 + staff 三方确认

7.4 模块四：平台管理后台扩展

ID	功能	优先级	实现要点
M4-01	渠道商列表/详情	P0	partner 表 + 状态机
M4-02	渠道商审核（含年审）	P0	§15 资质年审制度（《电商法》第 27 条）
M4-03	KYC 审核	P0	OSS 私有桶预览（presigned URL TTL ≤ 300s）+ OCR + 审核动作
M4-04	渠道商台账管理	P0	台账调整 / 冻结
M4-05	渠道商充值	P0	finance + 持牌分账方
M4-06	渠道商旗下客户列表	P0	drill-down
M4-07	全部客户列表	P0	filter; elevated audit
M4-08	模型管理 + 上游渠道	P0	复用 Fy-api 后台
M4-09	套餐管理	P0	复用 + Tracebex License 套餐类型
M4-10	平台收入统计 dashboard	P0	跨库聚合 / HTTP API
M4-11	分润报表 + 结算批次	P0	settlement + settlement_item + settlement_run
M4-12	充值/退款管理	P0	refund 流 + 审计
M4-13	发票管理	P0（升级）	invoice
M4-14	系统设置	P0	biz_setting
M4-15	操作日志	P0	append-only audit_log + 哈希链（§8.13 / §16）
M4-16（NEW）	资质年审入口	P0	partner 年审 reminder + 状态
M4-17（NEW）	内容安全审核中心	P0	§7.12；违规命中事件审核

7.5 模块五：分润结算

ID	功能	优先级	实现要点
M5-01	月结 Cron	P0	K8s Lease 优先 (Redis SETNX 备选)；时区固定 UTC+8 02:30；状态机 settlement.status
M5-02	周结 Cron	P1	同上
M5-03	T+0 实时分润记录	P2	outbox 实时性已经够 (§9.3)
M5-04	结算批次生成	P0	settlement_run 心跳 + progress_offset 续跑
M5-05	渠道商账单生成 (PDF + Excel)	P0	maroto + go-csv
M5-06	邮件通知	P0	SMTP via Fy-api 共享配置；trace_id 跟踪
M5-07	渠道商账单查看/下载	P0	partner backend
M5-08	平台审批 + 持牌分账下账	P0	持牌方 SDK + 凭证落库
M5-09	争议工单 (场景 K)	P0 (升级)	billing_dispute 状态机
M5-10 (NEW)	代扣个税步骤	P0	settlement_item.withheld_tax；详见 §15
M5-11 (NEW)	结算配置变更审计	P0	切换 monthly→weekly 写入 settlement_config_change_log；不影响在途 period

7.6 模块六：支付系统 (REWRITTEN)

v0.1 是教科书级”二清”。v0.2 必须走持牌路径。

资金流 (合规版)

客户付款 → 持牌分账方收单 (连连/易宝/汇付/合利宝等)

↓

持牌分账方按 TraceNex 指令做"实时分账 / T+1 分账"

↓

平台分账主体 (结算账户)	渠道商分账子账户
(运营成本 + 平台佣金)	(应得分润, T+1 / 月结)

- 客户钱**不进** TraceNex 的台账（不是“先收后转”）
- 平台主体的微信 / 支付宝商户号（mchid）仅作为 ISV 服务商身份的佣金接收主体，不作为客户付款的收款方（避免回到二清）
- `partner_wallet.balance`（v0.2 重新定义）= 平台应付给渠道商的累积分润负债（待月结分账下账）
- 客户的可用额度还是 `User.quota`（Fy-api 侧），**没有** TraceNexBiz 的客户钱包概念

ID	功能	优先级	实现要点
M6-01	持牌分账方 SDK 接入	P0	选定 1 家（Q12, §13）；MVP 期可以先支持 1 家
M6-02	商户号 / 子账户开立	P0	平台主商户号 + 每个 partner 子账户（KYC 通过后开立）
M6-03	客户支付（PC + H5 + 扫码）	P0	微信 / 支付宝渠道走 ISV 模式
M6-04	EPay 过渡	P1	复用 Fy-api 现有，但 不允许 进入 partner 分润流（仅直营客户）
M6-05	Stripe（海外）	P1	SG 站点；走平台主体收单 + 服务贸易开票
M6-06	退款	P0	持牌方退款 API + 审核 + 反向 saga
M6-07	防重 + 幂等 + 签名校验	P0	微信/支付宝 V3 RSA 验签 + IP 白名单 + (<code>channel</code> , <code>out_trade_no</code>) UNIQUE 去重
M6-08 (NEW)	金额校验	P0	回调金额必须 == 服务端订单创建时金额；不一致告警 + 拒绝
M6-09 (NEW)	持牌方分账下账	P0	月结后下账；失败重试；流水落 <code>settlement_item.payout_evidence</code>

7.7 模块七：实名认证（KYC）

ID	功能	优先级	实现要点
M7-01	企业认证（营业执照 OCR）	P0	阿里云 OCR API；图片只能上传到私有 OSS bucket；presigned URL TTL ≤ 300s
M7-02	个人实名（支付宝芝麻认证）	P0	收成功 / 失败 boolean， 不接收原始身份证号
M7-03	法人身份证	P0	OCR + 校验姓名一致
M7-04	审核流	P0	<code>kyc_application</code> 状态机 (§14)
M7-05	重审	P0	驳回后允许；3 次/年上限（场景 L）
M7-06	信息加密存储（KMS 信封）	P0	§19
M7-07	30 天热存储清原图 + 5 年冷归档	P0	OSS lifecycle: 30 天后从热桶搬到 OSS Archive (KMS 加密)；保留 5 年（《反洗钱法》§15)
M7-08 (NEW)	年龄校验	P0	身份证号读取出生年月，必须 ≥ 18 岁
M7-09 (NEW)	单独同意 + 告知	P0	UI 双层勾选；写 <code>consent_log</code> (§16)
M7-10 (NEW)	PIA 报告（年度）	P0	留档 ≥ 3 年

7.8 模块八：发票（升级 P0）

涉税链路上线必须打通；不能“v1.x 再说”（合规要求，§15）。

ID	功能	优先级	实现要点
M8-01	抬头管理	P0	invoice_title
M8-02	申请发票	P0	invoice_application
M8-03	财务审核 (≥ 5 类 驳回)	P0	后台动作 + 驳回理由 taxonomy
M8-04	全电发票对接	P0	国税总局全电系统 SDK
M8-05	邮寄/电子发票	P0	邮件附件
M8-06 (NEW)	个人渠道商代扣代 缴个税凭证	P0	settlement_item.tax_evidence_url (§15)

7.9 模块九：客户体验 / 防绕过 (NEW)

ID	功能	优先级	实现要点
M9-01	渠道商品品牌可见	P0	customer 后台显示「由 X 提供服务」(不可隐藏)
M9-02	防直营绕过	P0	已绑定渠道商的客户, 访问 aitracenex.com/topup 公开页时 redirect 回渠道商 页面
M9-03	白标支持	P2 (v1.2+)	自定义 logo / 色卡; contracts 决定
M9-04	渠道商 sandbox / demo	P1	提供 demo partner 让销售 演示

7.10 模块十：客服 / 工单 (NEW)

ID	功能	优先级	实现要点
M10-01	工单创建 (客户 / 渠道 商)	P0	ticket 表 + 状态机 (open → assigned → resolved → closed)
M10-02	后台分配	P0	support 角色处理
M10-03	上下文显示 (用量 / 账 单 / KYC 状态)	P0	drill-down
M10-04	SLA 指标 (<24h 响 应)	P0	监控 + 邮件告警

7.11 模块十一：通知（NEW）

ID	功能	优先级	实现要点
M11-01	事件中心	P0	event_catalog（账单生成、KYC 审核、余额低、发票完成等约 20 个事件）
M11-02	通道：邮件 / 站内信 / SMS / Webhook	P0（邮件 + 站内信） / P1（其他）	NotificationDispatcher
M11-03	用户偏好	P1	per-event 偏好
M11-04	重要事件强制（如月结 / KYC 驳回）	P0	不可关闭

7.12 模块十二：内容安全（NEW, BLOCK 整改）

来自合规 BLOCK #2。

ID	功能	优先级	实现要点
M12-01	模型上架白名单	P0	仅展示已通过《暂行办法》备案的模型；其他模型对中国用户隐藏
M12-02	输入侧关键词 + 分类模型审核	P0	国产合规审核服务（如阿里云内容安全 / 腾讯天御）；命中拦截 + 告警
M12-03	输出侧分类拦截	P0	同上；针对违法/敏感内容
M12-04	违法内容上报	P0	暂行办法 §14；构建上报通道（网信办 / 公安）
M12-05	深度合成水印	P0	图/视频/音频生成模型输出强制水印（《深度合成管理规定》§16-17）
M12-06	算法备案	P0	详见 §15
M12-07	责任分层条款（用户协议）	P0	见附录 B

8. 数据模型

GORM v2 风格描述。所有表加 `created_at` `updated_at`；除 `audit_log`（追加只写）外都有 `deleted_at`。所有金额单位：quota（与 Fy-api 一致），int64。

8.1 渠道商 `partner`

```
type Partner struct {
    ID                int64
    FyUserId          int64      // ★ 关联 Fy-api users.id (BIGINT 升级后)
    InvitationCode    string     // 唯一邀请码
    Status            int8      // 见 §14 状态机
    KycType           int8      // 0=未认证 1=企业 2=个人
    KycStatus         int8      // 0=未提交 1=待审核 2=通过 3=驳回 4=年审中
    KycExpiresAt      *time.Time // 年审到期
    DefaultRevenueShare float64    // 仅 default_share 模式（兼容路径）
    Tier              int8      // markup tier 0-9 (v1.0 以 tier 而非 per-customer 实现, §9
    AppliedAt         time.Time
    ApprovedAt        *time.Time
    ApprovedBy        *int64    // staff.id
    ContactName       string
    ContactPhone      EncryptedString // §19
    ContactEmail      string
    Notes             string     // 内部备注
    SettlementProviderId *int64    // 哪家持牌分账方的子账户
    ProviderSubAccountId string     // 子账户号
    FrozenAt          *time.Time
    FrozenReason      string
    TerminatedAt     *time.Time
    TerminatedReason string
}
```


8.2 终端客户 `customer`

```
type Customer struct {
    ID                int64
    FyUserId           int64      // ★ 关联 Fy-api users.id
    PartnerId          *int64     // ← NULL 表示直营客户
    JoinedVia          string      // 'invitation' / 'manual_create' / 'self_register_with_c
    InvitationCodeUsed string
    Status             int8       // 见 §14
    GroupNameInFyApi   string      // partner_X_tier_Y 形式, per-tier
    QuotaLimit          int64     // 0 = 不限
    TransferredFrom     *int64     // partner_id (场景 H/I)
    TransferredAt       *time.Time
}
```

8.3 渠道商台账 `partner_wallet` (重新定义)

v0.2 重要：这不是“为渠道商保管的客户付款”，而是“平台应付给渠道商的累积分润负债”。

```
type PartnerWallet struct {
    ID                int64
    PartnerId          int64      UNIQUE
    Balance            int64     // 累积应付分润 (quota 单位)
    HeldAmount         int64     // 进入 saga 但未提交的金额 (计算可用 = Balance - HeldAmount)
    PaidOutTotal       int64     // 历史已通过持牌方下账的累积
    Version            int64     // 乐观锁
}
```

8.4 钱包流水 `partner_wallet_log`

```
type PartnerWalletLog struct {
    ID            int64
    PartnerId     int64
    Type          string // 'revenue_accrual' / 'allocate_to_customer' / 'settlement_payout'
    Amount        int64  // 正/负
    BalanceAfter  int64
    RefId         string // saga_id / settlement_id / customer_id 等
    IdempotencyKey string UNIQUE
    Status        string // 'pending' / 'committed' / 'compensated'
    Note         string
    OperatorType  string // 'partner' / 'system' / 'platform_staff'
    OperatorId    int64
}
```

8.5 钱包 hold 表 `wallet_hold` (NEW)

```
type WalletHold struct {
    ID            int64
    WalletID      int64      INDEX
    PartnerId     int64      INDEX
    Amount        int64
    SagaID        string      UNIQUE // 也是 idempotency key
    Status        string      // 'held' | 'committed' | 'released'
    HeldAt        time.Time
    ResolvedAt    *time.Time
}
```

用法：可用余额 = `Balance - SUM(hold WHERE status='held')`。Saga 提交时 hold → committed；失败时 hold → released。

8.6 渠道商定价规则 `partner_pricing_rule` (重新设计)

v0.2 不再是单标量 markup。

```

type PartnerPricingRule struct {
    ID          int64
    PartnerId   int64      INDEX
    CustomerId  *int64      // NULL = partner 默认; 非 NULL = 客户级覆盖
    ModelName   *string      // NULL = 全模型; 非 NULL = 模型级覆盖
    TierName    *string      // 如 'enterprise', 可选
    Markup      decimal.Decimal // shopspring/decimal, 避免 float drift
    ValidFrom   time.Time
    ValidTo     *time.Time // NULL = 永久 (直到被另一条 rule 覆盖)
    Status      string      // 'active' / 'archived' / 'draft'
    CreatedBy   int64
    Note        string
}
// UNIQUE(partner_id, customer_id, model_name, tier_name, valid_from)
// 优先级 (resolved by service layer):
//    exact (customer_id + model_name) > customer_id > model_name > partner default

```

8.7 收益记录 `revenue_log`

```

type RevenueLog struct {
    ID          int64
    PartnerId   int64      INDEX
    CustomerId  int64      INDEX
    FyApiLogId   int64      UNIQUE // * 防重复消费 outbox
    Occurrence   int8        // 1=正常 2+=显式调整 (与 fy_api_log_id 联合保证幂等)
    GrossAmount  int64      // 客户被扣金额 (已含 markup)
    CostAmount   int64      // 平台成本
    NetRevenue   int64      // 渠道商分润
    AppliedRuleId int64      // 引用 partner_pricing_rule.id
    OccurredAt   time.Time
    SettlementId *int64
}
// UNIQUE(fy_api_log_id, occurrence)

```

8.8 结算批次 `settlement` + `settlement_item` + `settlement_run`

```
type Settlement struct {
    ID                int64
    Period            string          // 'monthly_2026_05'
    PeriodStart       time.Time
    PeriodEnd         time.Time
    Timezone          string          // 'Asia/Shanghai'
    TotalRevenue      int64
    TotalCost         int64
    TotalPayout       int64
    Status            string          // 见 §14: generating/generated/paying/paid/failed
    ProgressOffset    int64          // 续跑游标
    GeneratedAt       time.Time
    PaidAt            *time.Time
    PaidBy            *int64
    PaymentEvidence   string
}

type SettlementItem struct {
    ID                int64
    SettlementId      int64
    PartnerId        int64
    Revenue           int64
    Cost              int64
    PlatformFee       int64
    WithheldTax       int64          // §15 个税
    Payout            int64          // = Revenue - Cost - PlatformFee - WithheldTax
    TaxEvidenceUrl    string
    Status            string          // 'pending' / 'paid' / 'disputed'
    ProviderTradeNo   string          // 持牌分账方流水
    InvoiceId          *int64
    IsPartial         bool          // 跨期入驻 (场景 0)
}

// UNIQUE(settlement_id, partner_id)

type SettlementRun struct {
    ID                int64
    SettlementId      int64
    Hostname          string
    Pid              int
    StartedAt         time.Time
    LastHeartbeat     time.Time
}
```

```

    EndedAt      *time.Time
    Status       string          // 'running' / 'completed' / 'crashed' / 'taken_over'
}
// 用于跨实例 cron 续跑 (§14)

type SettlementConfigChangeLog struct {
    ID            int64
    ChangedBy     int64
    OldPeriod     string
    NewPeriod     string
    EffectiveFrom time.Time
    Reason       string
}

```

8.9 KYC 申请 `kyc_application`

```

type KycApplication struct {
    ID            int64
    FyUserId      int64
    Type          int8          // 1=企业 2=个人
    Status        int8          // §14 KYC 状态机
    BusinessLicenseUrl string      // OSS 私有 URL, 30 天后清; 指向 OSS Archive 5 年
    BusinessLicenseOcr string      // OCR 提取结果
    LegalPersonName EncryptedString
    LegalPersonIdNo EncryptedString
    LegalPersonIdUrl string
    LegalPersonIdArchiveUrl string // 冷归档地址
    AlipayOpenId   EncryptedString
    AlipayRealName EncryptedString
    EncryptionKeyId int          // §19, KMS 密钥版本
    SubmittedAt    time.Time
    ReviewedAt     *time.Time
    ReviewedBy     *int64
    RejectReasonCode string      // 5 类驳回 taxonomy
    RejectReasonText string
    PiiPurgedAt    *time.Time // 热存储清理时间 (30d)
    ColdArchiveExpiresAt *time.Time // 冷归档 5 年
}

```

8.10 邀请码 `invitation_code`

```
type InvitationCode struct {
    ID          int64
    PartnerId   int64
    Code        string    UNIQUE    // ≥ 16 字符高熵
    Type        string    // 'permanent' / 'one_time' / 'limited'
    UsageLimit  int       // 0 = 不限
    UsedCount   int
    ExpiresAt   *time.Time
    Status      string    // 'active' / 'expired' / 'revoked'
}
```

8.11 席位 `seat`

```
type Seat struct {
    ID          int64
    OwnerType   string
    OwnerId     int64
    Name        string
    FyTokenId   int64
    PurchasedAt time.Time
    ExpiresAt   time.Time
    Status      string
}
```

8.12 发票 `invoice_application` + `invoice_title`

```
type InvoiceApplication struct {
    ID            int64
    ApplicantType string
    ApplicantId    int64
    TitleId        int64
    Amount         int64
    Period         string
    Status         string    // §14
    InvoiceUrl      string    // 全电发票 PDF
    MailAddress    string
    AppliedAt      time.Time
    IssuedAt       *time.Time
    Notes          string
    RejectReasonCode string
}

type InvoiceTitle struct {
    ID            int64
    OwnerType     string
    OwnerId       int64
    TitleType     int8    // 1=个人 2=企业
    Title         string
    TaxNumber     string
    BankInfo      string
    IsDefault     bool
}
```

8.13 操作日志 `audit_log` + `audit_log_pii` (重写: 追加只写 + 哈希链)

```
type AuditLog struct {
    ID            int64
    ActorType     string
    ActorId       int64
    Action        string           // verb (与 §3.4 权限矩阵对应)
    TargetType    string
    TargetId      int64
    DiffRedacted  string           // PII 脱敏后的 diff
    DiffPiiId     *int64           // 指向 audit_log_pii, 可被 PIPL 删除
    IpAddress     string
    UserAgent     string
    TraceId      string
    OccurredAt    time.Time
    PrevHash     string           // sha256(prev row's self_hash)
    SelfHash     string           // sha256(canonical_serialize(this row except self_hash))
}

// 表设计: 应用 user 仅 SELECT + INSERT; UPDATE/DELETE 拒绝
// trigger 检查 PrevHash 一致性

type AuditLogPii struct {
    ID            int64    PRIMARY KEY
    DiffJson     string    // 含 PII 的原始 diff
    EncryptionKeyId int
    TombstonedAt *time.Time // PIPL 删除请求后置位
}
```

8.14 平台 staff `staff`

```
type Staff struct {
    ID            int64
    Username      string
    PasswordHash  string
    Role          string    // §3.2
    Email         string
    Status        string
    LastLogin     *time.Time
    MfaSecret     EncryptedString // TOTP; 强制启用
    WebauthnCreds string    // 多 credential JSON
}
```


8.15 系统配置 `biz_setting`

```
type BizSetting struct {
    Key          string PRIMARY KEY
    Value        string
    UpdatedAt    time.Time
    UpdatedBy    int64
}

// 关键 keys:
// settlement.period      = 'monthly' | 'weekly' | 't+0' | 't+7'
// settlement.day_of_month = '1'
// settlement.cutoff_hour  = '02'
// settlement.timezone    = 'Asia/Shanghai'
// default_revenue_share  = '0.20'
// max_markup             = '5.0'
// pii_purge_days_hot     = '30'
// pii_archive_years_cold = '5'
// trial_quota_usd        = '0.50'
// sync_freq_seconds      = '5' (Fy-api 覆盖层用, §9.2)
```

8.16 幂等记录 `idempotency_record` (NEW)

```
type IdempotencyRecord struct {
    ID            int64
    ActorType     string
    ActorId       int64
    IdempotencyKey string
    Endpoint      string
    RequestHash   string          // sha256(canonical_request)
    ResponseStatus int
    ResponseHash  string
    ResponseJson  string          // 完整 response 缓存
    CreatedAt     time.Time
    ExpiresAt     time.Time       // 24h TTL
}

// UNIQUE(actor_id, idempotency_key, endpoint)
// 重提同 key 但 RequestHash 不同 → 409 Conflict
```

8.17 Saga 步骤表 `saga_step` (NEW)

```
type SagaStep struct {
    ID          int64
    SagaId      string      INDEX      // = idempotency key
    StepName    string      // 'wallet.hold' / 'fy.topup' / 'wallet.commit' / 'wallet.release'
    Status      string      // 'pending' / 'in_progress' / 'committed' / 'compensated' / 'failed'
    Attempts    int
    LastError   string
    Payload     string      // JSON
    UpdatedAt   time.Time
}
```

8.18 工单 ticket + 通知 notification + 同意 consent_log (NEW)

```
type Ticket struct {
    ID          int64
    OpenerType  string
    OpenerId    int64
    Subject     string
    Category    string          // billing / kyc / api / other
    Status      string          // §14 工单状态机
    AssignedTo  *int64             // staff.id
    Priority     int8
    LastReplyAt time.Time
    SlaDueAt    time.Time
}

type TicketReply struct {
    ID          int64
    TicketId    int64
    SenderType  string
    SenderId    int64
    BodyMd      string
    Attachments string // JSON URLs
}

type NotificationOutbox struct {
    ID          int64
    Recipient   string          // user_id 或 email
    Channel     string          // 'email' / 'inapp' / 'sms' / 'webhook'
    EventCode   string          // 来自 event_catalog
    Payload     string
    Status      string          // 'pending' / 'sent' / 'failed' / 'dead_letter'
    RetryCount  int
    DispatchedAt *time.Time
}

type ConsentLog struct {
    ID          int64
    SubjectFyUserId int64
    ConsentType string // 'privacy_policy' / 'sensitive_pi' / 'biometric' / 'cross_b
    ConsentTextVersion string
    ConsentedAt time.Time
    Ip          string
    UserAgent   string
}
```

```

Withdrawn      bool
WithdrawnAt    *time.Time
}

```

8.19 计费消费 outbox `consume_log_outbox` (Fy-api 覆盖层提供)

```

-- 由 Fy-api 覆盖层 model/log.go 在 RecordConsumeLog 同事务写入
CREATE TABLE consume_log_outbox (
    id BIGINT PRIMARY KEY AUTO_INCREMENT,
    log_id BIGINT NOT NULL UNIQUE,
    user_id BIGINT NOT NULL,
    group_name VARCHAR(255),
    quota BIGINT,
    channel_id INT,
    model_name VARCHAR(255),
    occurred_at TIMESTAMP,
    consumed_at TIMESTAMP NULL,    -- TraceNexBiz consumer 标记
    INDEX idx_unconsumed (consumed_at, id)
);
-- TraceNexBiz poller 每秒扫 WHERE consumed_at IS NULL ORDER BY id LIMIT 1000

```

8.20 客户切换日志 `customer_partner_change_log` (场景 H)

```

type CustomerPartnerChangeLog struct {
    ID            int64
    CustomerId    int64
    FromPartnerId *int64
    ToPartnerId   *int64
    InitiatorType string // 'customer' / 'staff' / 'system_termination'
    InitiatorId   int64
    Reason        string
    OccurredAt    time.Time
    OldGroup      string
    NewGroup      string
}

```

9. 计费链路设计（核心难点，重写）

9.1 问题陈述

需求：渠道商 X 给客户 Y 设置 markup 1.30。客户 Y 调用 GPT-4o，平台批发价 \$0.005/1k。– 客户 Y 扣 \$0.0065 – 平台从 Y 收 \$0.0065（实际通过持牌方）– 渠道商 X 成本 \$0.005 – 渠道商 X 应得分润 \$0.0015
→ 累积到 partner_wallet.balance（应付台账）

9.2 group_ratio 实现（修订）

v0.1 设计：每个 partner+customer 一个 group → group 数量爆炸（10 万级）。v0.2 设计：**per-tier groups**（每渠道商 N 档， $N \leq 10$ ）+ Fy-api `User.GroupRatioOverride` 覆盖层字段。

v1.0 实现

1. partner X 创建时，覆盖层自动建若干 groups：`partner_X_tier_default`，`partner_X_tier_pro`，`partner_X_tier_enterprise` 等（最多 N 档，业务可配）
2. 每档 group_ratio 由 partner 在自己后台设置（受 max_markup 限制）
3. 客户 Y 加入时分配到合适 tier；`User.group = partner_X_tier_default`（原生 Fy-api 字段，覆盖层 API 写入）
4. **客户级覆盖**：通过 Fy-api 覆盖层新增的 `User.GroupRatioOverride float64` 字段，对个别 VIP 客户细粒度调整。Fy-api 计费链路读 `RelayInfo.GroupRatio`，覆盖层在 `getUserGroupRatio` 中加：

```
if user.GroupRatioOverride > 0:
    return user.GroupRatioOverride
return groupRatioMap[user.group]
```

group_ratio 传播

v0.1 谎言：“调价立刻生效”；事实：60 秒轮询。v0.2 真相：通过 **Redis Pub/Sub 失效缓存** 承诺 < 2 秒传播。

Fy-api 覆盖层（附录 C）：– `model/option.go::UpdateOption` 同步 publish `Redis: option_update {key}` 消息 – 每个 Fy-api 实例订阅该 channel，收到后立即 `loadOptionsFromDatabase()` 局部刷新 – 兜底：`SyncOptions(SyncFrequency)` 默认从 60s 降到 5s

group 数量 / 性能

- 每渠道商最多 10 档 → 1000 渠道商 = 10k groups → MySQL TEXT JSON < 1MB → 没问题
- 客户级 markup 走 `User.GroupRatioOverride`，不增加 group 数量
- 100 万级客户 / 1000 渠道场景下：groupRatioMap 内存 < 1MB

9.3 计费数据捕获 (REWRITTEN: CDC → outbox)

v0.1 推荐 canal CDC (MySQL-only, 违反 Fy-api 三方约定, schema-drift 风险高)。v0.2 改为应用层 outbox。

客户 Y 调 /v1/chat/completions

|

▼

Fy-api 现有计费 (text_quota.go)

|

▼

RecordConsumeLog (覆盖层增强):

BEGIN

INSERT INTO logs (...);

INSERT INTO consume_log_outbox (log_id, user_id, ...) -- 同 TX

COMMIT

|

▼

TraceNexBiz outbox poller (每 1s):

SELECT FROM consume_log_outbox

WHERE consumed_at IS NULL ORDER BY id LIMIT 1000

FOR EACH:

resolve partner_id from user_id (缓存 5 分钟)

resolve cost from log.quota / pricing_rule

INSERT INTO revenue_log (fy_api_log_id, ...) -- UNIQUE 防重

UPDATE consume_log_outbox SET consumed_at = NOW()

优势 vs B-1 (webhook) vs B-2 (CDC)

维度	B-1 webhook	B-2 CDC	B-3 outbox (v0.2)
侵入 Fy-api	大	0	~50 行 (覆盖层)
DB 兼容 (MySQL/PG/SQLite)	✓	✗	✓
延迟	实时	1-3s	1s
失败可重试	复杂	binlog 自然	outbox 自然 (poll until success)
schema 漂移风险	中	高	低 (显式契约)
事务一致性	弱 (异步)	强	强 (同事务)
上游同步压力	高 (每月冲突)	0	低 (仅一个新文件 + 一行 RecordConsumeLog 调用)

CDC 替代项 — 已废弃

v0.1 的 §11 row 7 “CDC 链路丢消息”无对应风险 —— outbox 模式下信息源是事务内 INSERT，落库即可见。

结算 freshness gate

settlement Cron 启动时检查: `MAX(occurred_at) FROM revenue_log ≥ NOW - 60s`。如果不满足 (outbox 大延迟), refuse to run + 告警。

9.4 Saga 详细规约（重写）

渠道商→客户分配额度（M3-04）

INPUT: PartnerID, CustomerFyUserID, Amount, IdempotencyKey

[Step 0] idempotency check

```
SELECT FROM idempotency_record WHERE actor_id=PartnerID AND idempotency_key=IdemKey
if exists with same RequestHash → return cached response
if exists with different RequestHash → 409 Conflict
```

[Step 1] wallet hold

```
BEGIN
LOCK PartnerWallet FOR UPDATE
check available = Balance - SUM(holds.held) >= Amount
INSERT INTO wallet_hold (saga_id=IdemKey, amount=Amount, status='held')
INSERT INTO saga_step (saga_id, step='wallet.hold', status='committed')
COMMIT
```

[Step 2] call Fy-api topup (带 IdemKey)

```
POST /api/internal/user/topup
Headers: X-Auth-* ($6.1) + Idempotency-Key: IdemKey
Body: {user_id, amount}
timeout: 10s
```

[Step 3] outcome

on 2xx with confirm:

```
BEGIN
UPDATE wallet_hold SET status='committed' WHERE saga_id=IdemKey
UPDATE partner_wallet SET balance = balance - Amount, version+=1
WHERE id=... AND version=v
INSERT INTO partner_wallet_log (... , status='committed', idempotency_key=IdemKey)
UPDATE saga_step (saga_id, step='wallet.commit', status='committed')
COMMIT
return success
```

on 4xx (deterministic fail):

```
BEGIN
UPDATE wallet_hold SET status='released' WHERE saga_id=IdemKey
UPDATE saga_step (saga_id, step='wallet.release', status='committed')
COMMIT
return error
```



```
on 5xx / timeout (ambiguous):
  ENQUEUE saga retry:
    GET /api/internal/topup/by-idem-key?key=IdemKey
    if "succeeded" → 走 2xx 分支
    if "failed"    → 走 4xx 分支
    if "unknown"   → 等待 + retry
    return 202 Accepted (前端 polling)
```

退款 (场景 J)

INPUT: RevenueLogID, RefundReason, IdemKey, Initiator

[Step 1] write negative revenue_log

```
INSERT INTO revenue_log (
  partner_id, customer_id, fy_api_log_id=originalLogId, occurrence=2,
  gross=-orig.gross, cost=-orig.cost, net=-orig.net,
  occurred_at=NOW()
)
```

[Step 2] refund customer's quota via Fy-api topup (带 IdemKey)

[Step 3] update partner_wallet:

```
if originalRevenue.SettlementId IS NULL:
  partner_wallet.balance -= orig.net  (clawback before settlement)
else if Settlement.Status in ('paying','paid'):
  write partner_wallet_log (type='refund_clawback', amount=-orig.net)
  balance go negative is OK (追偿到下个 period)
```

[Step 4] notify partner (\$7.11)

9.5 价格时间性

`partner_pricing_rule.ValidFrom/ValidTo` 决定哪条规则生效。`revenue_log.AppliedRuleId` 记录当时使用的规则，**历史 revenue 永远按当时规则**（不会因为规则改了就重算）。

10. 非功能性需求

10.1 性能

类别	指标
TraceNexBiz 内部 P95	< 500ms (不含外部调用)
端到端 P95 (含 Fy-api 调用)	< 800ms
outbox poll 延迟	< 2s (事件发生 → revenue_log 落库)
group_ratio 传播延迟	< 2s (partner 改 → 全实例生效)
列表页首屏	< 2s
月结跑完	< 30 min (10 渠道 × 1000 客户级别)
并发	TraceNexBiz 后台 ≥ 200 QPS

10.2 可用性

时段	SLO
MVP	99.5%
Phase 2 后	99.9%

10.3 数据持久性 + 备份

- RDS 自动备份每日 + 月结后单独 dump (加密 + 独立 OSS bucket + 只读 IAM)
- KYC 冷归档: 5 年 (§7.7 / §15)
- 计费数据: 3 年 (《电商法》§31)

10.4 事务一致性

- 钱包扣减 ACID (pessimistic lock + version 双保险)
- 跨服务用 saga + idempotency + 显式 by-idem-key 探活 (§9.4)
- 强禁止 XA 跨库

10.5 安全

详见 §16 / §17 / §18 / §19。

10.6 可观测性

- Prometheus 指标: QPS、错误率、saga 失败率、wallet drift (partner_wallet.balance vs SUM(partner_wallet_log.amount) 应等)、settlement 成功率、outbox lag、KYC SLA

- 结构化 JSON 日志 + 自动 PII scrubber (中间件层 strip 标记 `pii:"true"` 字段、识别身份证号 / 手机号 / email pattern 自动 redact)
- trace_id: 复用 Fy-api 的 `X-0neapi-Request-Id` , 跨内部 API 透传, 落入所有日志 + revenue_log + saga_step
- wallet drift 每日对账 → page on > 0
- 监控: 阿里云 SLS (与 Fy-api 同生态)

10.7 国际化

- 中英文界面
- 国际客户在 SG 实例: CAC 标准合同已签 (§15)

10.8 可配置性

biz_setting 全部覆盖 (结算周期、默认分润、试用额度、max_markup 等)

10.9 可维护性

- Go 单元测试覆盖 $\geq 70\%$
 - 前端核心流程测试 $\geq 60\%$
 - BOLA / IDOR 越权测试: 100% 读端点覆盖 (CI 强制)
 - gosec / govulncheck / bun audit pre-merge gate
-

11. 风险与对策

ID	风险	等级	类型	对策	责任人
R-1	二清 / 无证清算	●●●●	合规	持牌分账方托管 (§7.6 / §15)	财务 + 法务
R-2	生成式 AI 内容 违规连带责任	●●	合规	§7.12 双层审核 + 模型白名单 + 算法备案	合规
R-3	个人渠道商代扣 代缴未履行	●	税务	§15 月结嵌入代扣 + 41 号公告报送	财务
R-4	ICP 经营许可证 未取得	●	合规	Week 0 启动; Phase 2 上线前 hard-gate	法务
R-5	PII 泄露 / KYC 资料	●	安全	§19 KMS 信封 + 私 有 OSS + 短 TTL presigned URL + 日 志 PII scrubber	安全
R-6	数据归属越权 (BOLA)	●	安全	§16 + §3.4; CI 强 制矩阵越权测试	工程
R-7	钱包资金事务一 致性 / 双花	●	安全/财务	§9.4 saga + wallet_hold + idempotency	工程
R-8	Fy-api 内部 API HMAC key 泄露	●	安全	mTLS + key rotation + per- service 范围 (§6.1, §17)	安全
R-9	审计日志被篡改 / 删除	●	合规/安全	append-only + 哈希 链 + 应用 user 无 UPDATE/DELETE 权限 (§8.13)	安全
R-10	支付回调被篡改 / 重放	●	安全	签名 + IP 白名单 + amount 校验 + dedup (§7.6 M6- 07/08)	工程
R-11	数据跨境无 CAC 标准合同	●	合规	SG 上线前完成 (§15)	合规
R-12	平台对渠道商资 质未尽审核 (电 商法 27/38)	●	合规	M4-02 强化年审制 度 (§15)	运营

ID	风险	等级	类型	对策	责任人
R-13	未成年人 KYC 通过	🟡	合规	M7-08 年龄校验	工程
R-14	微信/支付宝 ISV 资质周期	🟡	业务	早 4-6 周启动	运营
R-15	结算 Cron 重复 / 中断	🟡	工程	K8s Lease + settlement_run 心跳 + progress_offset 续跑 (§14)	工程
R-16	outbox 积压	🟡	工程	容量监控 + 告警 $\geq 80\%$; retry/dead-letter	工程
R-17	争议导致客户投诉	🟡	业务	M5-09 (§7.5) + §7.10 工单	客服
R-18	markup 上下限被恶意设置	🟡	安全	§16 + §M3-13 服务端校验	工程
R-19	Fy-api 覆盖层在月度 sync 时冲突	🟡	工程	全部新文件; OVERLAY.md 跟踪; CI conflict-detector	工程
R-20	试用额度刷量	🟡	业务	§M1-08 IP/设备指纹 + 延迟发放	工程
R-21	客户跨渠道商挖墙脚	🟡	业务	§4.8 / §4.14 双方 + staff 三方确认	产品
R-22	LOG_DB 拆分导致跨库 join 失效	🟡	工程	双路径报表 (§6.3)	工程
R-23	group 数量过多 / groupRatioMap 内存	🟢	工程	per-tier 模型 + GroupRatioOverride (§9.2)	工程
R-24	CIIO 认定后跨境必须安全评估	🟢	合规	用户量监控; 触发后启动评估	合规
R-25	LLM 输出版权 / 隐私问题	🟢	合规	用户协议条款 + 内容安全	法务

12. 里程碑（10–12 周完整商业化上线）

12.0 Week 0（合规 + 准备并行启动）

平行启动（不能串行）：– ICP 经营许可证申请（90 工作日，**hard-gate Phase 2**）– 公司主体确认（注册资本 100 万实缴 / 1 年经营）– 持牌分账方选定 + 接入对接（连连/易宝/汇付/合利宝候选，§15 Q12）– 律师起草《用户协议》《隐私政策》《渠道商合作协议》– 算法备案 / 大模型白名单核查 – DPO 任命 – ops 拓扑决定（K8s deployment vs Podman 单机）– BIGINT 升级 spike（`User.Quota` / `Log.Id`）– Fy-api 覆盖层 PR 设计 spike（附录 C）– PRD v1.0 定稿 + git init

12.1 Phase 1 — MVP 内测（4 周，Week 1–4）

目标：5 家种子渠道商端到端走完。**钱包从第 1 天就用**（不“绕过”），但渠道商初始余额由平台 staff 预拨（避免 Phase 1 引入支付）。

范围：– M1-04 / M1-06 / M1-09 – M2-01 / M2-02 / M2-05 / M2-08 / M2-09 / M2-11 / M2-12（KYC stub）/ M2-13 / M2-14 – M3-01 / M3-02 / M3-03 / M3-04（通过 **wallet hold + saga**）/ M3-09 / M3-13（markup 单层）– M4-01 / M4-02 / M4-04 / M4-05 / M4-06 / M4-07 / M4-15 – M9-01 / M9-02 – 数据模型：partner / customer / wallet / wallet_hold / wallet_log / pricing_rule / revenue_log（无结算字段）/ invitation_code / audit_log + audit_log_pii / staff / idempotency_record / saga_step / consent_log – Fy-api 覆盖层（附录 C）：– 内部 API + HMAC + mTLS (§6.1) – BIGINT migration – GroupRatioOverride 字段 – consume_log_outbox 表 + 同事务写入 – Redis Pub/Sub option invalidate – 内容安全：M12-01 模型白名单（仅展示已备案模型）、M12-02 输入侧关键词审核（基础版）– 合规：单独同意 UI、consent_log、PIA 草稿启动

Phase 1 退出条件：见 §1.4 Phase 1 退出条件 + Fy-api 覆盖层 PR 已合并 + KYC stub + 内容安全基础版上线 + ICP 申请受理 + 持牌方测试环境联调通过

12.2 Phase 2A — 商业化基础（3 周，Week 5–7）

目标：钱包 + 客户充值（持牌方）+ KYC + 内容安全完整 + outbox 接入。

范围：– M2-03（持牌方收单）/ M2-04 线下转账 / M2-13 余额预警 – M3-05 / M3-08（多层 pricing_rule）/ M3-12 / M3-14 – M4-03 / M4-08 / M4-09 / M4-10 / M4-12 / M4-16 / M4-17 – M6-01 / M6-02 / M6-05 / M6-07 / M6-08 – M7-01 ~ M7-10 完整 – M11 通知中心（邮件 + 站内信）– M12-02 / M12-03 / M12-05 / M12-04 完整内容安全 – outbox poller + revenue_log 落库 – Redis Pub/Sub 投产

外部并行：微信/支付宝 ISV 资质审核（4–6 周）；持牌分账方正式签约。

12.3 Phase 2B — 商业化结算（2–3 周，Week 8–10）

目标：月结 + 持牌分账下账 + 发票 + 个税代扣。

范围：– M5-01 / M5-04 / M5-05 / M5-06 / M5-07 / M5-08 / M5-09 / M5-10 / M5-11 – M6-09 持牌方分账下账 – M8-01 ~ M8-06（含个税凭证）– M4-11 / M4-13 – 全电发票对接

Phase 2 总退出条件: §1.4 Phase 2 退出条件 + ICP 证已下 + 算法备案完成 + 等保 2.0 二级备案完成 + 持牌方上线运行 + PIA 报告留档

12.4 Phase 3 — 企业级补完 (2–4 周, Week 10–13)

目标: 发票完善、席位、客户额度、争议、白标 v1.

范围: – M2–06 / M2–10 / M2–15 完整 – M3–06 / M3–11 – M5–09 完整争议流 – M9–04 demo / sandbox

12.5 跨期合规轨

资质 / 流程	启动	完成	责任人
ICP 经营许可证	Week 0	Week 12+	法务
算法备案	Week 1	Week 8	合规
大模型备案核查	Week 0	上线前	合规
等保 2.0 二级	Week 4	Week 12	安全
PIA	Week 4	Week 8	合规
隐私 / 用户 / 渠道商协议	Week 1	Week 6	法务
CAC 标准合同 (SG)	SG 启用前 4 周	SG 启用	合规
微信 / 支付宝 ISV	Week 0	Week 6	财务
持牌分账方接入	Week 1	Week 4	财务
反洗钱客户身份识别制度	Week 4	Week 8	风控

13. 待业务进一步确认的问题

v0.2 重新分类：BLOCK / WARN / INFO，并标注 due date。Q3 / Q4 / Q10 不是“待确认”——见 §15。

#	问题	影响	等级	Due
Q1	默认渠道商分润比例多少？是否所有渠道商一致？	产品定价	WARN	Week 2
Q2	第一批种子渠道商的目标行业	KYC 严格度 / 合同模板	INFO	Week 3
Q3	个人渠道商代扣代缴	法律强制 (§15)	—	—
Q4	内容审核	法律强制 (§7.12 / §15)	—	—
Q5	海外客户分润换汇	SG 国际化	WARN	Week 6
Q6	退款规则（无理由退款窗口）	§9	BLOCK	Week 1
Q7	全电发票自建 vs 对接航天信息	§7.8	WARN	Week 4
Q8	渠道商跑路客户处置详细规则	§4.9	WARN	Week 5
Q9	渠道商互相挖墙脚是否允许	§4.14	WARN	Week 5
Q10	平台佣金抽成位置	影响 §9 实现	BLOCK	Week 1
Q11 (NEW)	公司主体注册资本是否 ≥ 100 万实缴	ICP	BLOCK	Week 0
Q12 (NEW)	持牌分账方选哪家	§7.6 / §15	BLOCK	Week 1
Q13 (NEW)	DPO 由谁担任 (PIPL §52)	§15	BLOCK	Week 1
Q14 (NEW)	算法备案文本（算法机制 / 应用场景描述）	§15	BLOCK	Week 2
Q15 (NEW)	多币种 / 换汇政策	SG	WARN	Week 8
Q16 (NEW)	平台 → 渠道商签约模板	法务	BLOCK	Week 1
Q17 (NEW)	最低支付门槛（≤ 阈值不下账）	§7.5	WARN	Week 4
Q18 (NEW)	客户列表对渠道商的 NDA / 出口管控	§11 / §16	INFO	Week 6

#	问题	影响	等级	Due
Q19 (NEW)	max_markup 上限（默认 5.0 是否合理）	§M3-13	WARN	Week 2
Q20 (NEW)	归属窗口（已绑客户多久后还认账）	业务	INFO	Week 6

BLOCK = 不解必停代码；**WARN** = Phase 2 上线前必须解；**INFO** = Phase 3 / 公开发布前解

14. 状态机 (NEW)

14.1 Partner 状态机

```
applied → reviewing
reviewing → approved | rejected
rejected → applied (重审, 年内 ≤ 3 次)
approved → frozen (合规 / 风控)
approved → suspended (KPI / 自愿)
frozen → approved | terminated
suspended → approved | terminated
approved → terminated (永久)
任意 → terminated
```

14.2 Customer 状态机

```
active → disabled (partner 操作 / 合规)
active → transferred (场景 H)
active → orphaned (其 partner 终止, 30d 宽限)
orphaned → adopted (新 partner 接收) | direct (转直营)
任意 → deleted (PIPL Article 47, 5d 后软删除生效)
```

14.3 Settlement 状态机

```
generating → generated → paying → paid
      ↓
      failed → generating (retry by Cron)

paid + dispute → partially_disputed
```

14.4 KYC 状态机

```
draft → submitted → under_review → approved | rejected
rejected → submitted (≤ 3次/年)
approved → expiring (30d 前提醒) → expiring → expired (年审)
expired → submitted
```

14.5 Dispute 状态机

opened → partner_responding (1 工作日 SLA) → escalated → arbitrating → upheld | overruled
upheld → triggers refund (\$4.10)
任意 → withdrawn

14.6 Saga 状态机

init → wallet_held → fy_topup_pending → fy_topup_unknown → fy_topup_known
↓
retry by-idem-key
fy_topup_known → committed | released

14.7 Ticket 状态机

open → assigned → responding → waiting_user → resolved → closed
任意 → reopened

15. 合规与资质计划 (NEW, BLOCK 级)

来自 Compliance Round-1 的 4 项 BLOCK_LAUNCH + 8 项 PRE_LAUNCH。Phase 2 商业化上线 hard-gated 在以下条目通过。

15.1 资质 / 流程清单

项目	主管单位	起	止	责任	等级
公司主体确认 (注册资本 100 万实缴)	—	Week 0	Week 0	法务	● BLOCK
ICP 经营许可 证	通信管理局	Week 0	Week 12+	法务	● BLOCK
生成式 AI 提供 者备案 + 算法 备案	网信办	Week 1	Week 8	合规	● BLOCK
大模型上架白 名单 (仅展示 已备案)	网信办清单	Week 0	持续	合规	● BLOCK
持牌分账方接 入 (去二清)	央行	Week 1	Week 4	财务	● BLOCK
等保 2.0 二级 备案	公安	Week 4	Week 12	安全	● PRE_LAUNCH
PIA 报告	内部	Week 4	Week 8	合规	● PRE_LAUNCH
隐私政策 / 用 户协议 / 渠道 商合作协议	内部 + 律师	Week 1	Week 6	法务	● PRE_LAUNCH
数据出境 CAC 标准合同 (SG)	网信办备案	SG 启用前 4 周	SG 启用	合规	● PRE_LAUNCH
微信 / 支付宝 ISV 商户号资 质	微信 / 支付宝	Week 0	Week 6	财务	● PRE_LAUNCH
反洗钱客户身 份识别制度	内部	Week 4	Week 8	风控	● PRE_LAUNCH
DPO 任命 + 公 示	内部	Week 0	Week 4	法务	● PRE_LAUNCH
个人渠道商代 扣代缴个税方 案	财务 + 税务	Week 1	Week 8	财务	● BLOCK
全电发票对接	国税总局	Week 4	Week 10	财务	● PRE_LAUNCH

15.2 资金流去二清要点

- 客户付款永远不进入 TraceNex 直接控制的账户 → 进入持牌分账方的备付金池

- **平台主体**通过持牌方的 ISV / 服务商身份获得佣金
- **渠道商分润**通过持牌方的”分账”操作（持牌方主导）下账到渠道商**自有商户号** / 持牌方为其开立的子账户
- `partner_wallet.balance` = “持牌方账面上、平台应付而未支付给渠道商的累积金额台账”，**不是**沉淀的客户付款

15.3 内容安全合规要点（详见 §7.12）

- 输入侧：阿里云内容安全 / 腾讯天御等国产合规审核服务
- 输出侧：分类拦截违法 / 敏感内容
- 命中事件：自动告警 + 24h 内人工 review
- 违法内容上报：暂行办法 §14
- 深度合成水印：图 / 视频 / 音频生成强制（§深度合成规定 §16–17）

15.4 个人渠道商代扣代缴

settlement_item 计算：

```
Gross      = SUM(revenue_log.gross)
Cost       = SUM(revenue_log.cost)
PlatformFee = Gross × platform_fee_rate
WithheldTax = ComputeWithheldTax(NetBeforeTax, partner.kyc_type, partner.tax_status)
Payout     = Gross - Cost - PlatformFee - WithheldTax
```

代扣规则（劳务报酬税）：- ≤ 800 元：不扣 - 800–4000：(收入 - 800) × 20% - 4000–25000：收入 × 80% × 20% - 25000–62500：收入 × 80% × 30% - 2000 - > 62500：收入 × 80% × 40% - 7000

平台年度向税务报送（41 号公告）。如渠道商升级为个体工商户 / 个独并提供完税证明 → 走另一路（增值税链条）。

15.5 PIPL 单独同意 UI

KYC 提交页：

- ☐ 我已阅读《用户协议》《隐私政策》（必勾，进入下一步）
- ☐ 我【单独同意】TraceNex 收集我的身份证号、生物特征（人脸）信息并用于实名认证。本同意可随时撤回。

写入 `consent_log`（含 ip / ua / consent_text_version）。

15.6 KYC 数据保留

- 热存储（业务系统）：30 天
- 冷归档（OSS Archive, KMS 加密）：5 年（《反洗钱法》§19）
- 5 年后不可逆删除
- PIPL 删除请求：见 §4.17

15.7 跨境数据 (SG)

- CAC 标准合同 + 网信办备案
- 中国用户的 PII 默认在 CN 实例；SG 实例只接 SG 用户 PII
- 跨实例运维操作：日志记录，DPO 审批

15.8 电商法平台资质审核

- 渠道商 = “平台内经营者” (《电商法》§9)
- TraceNex = 平台运营者，承担 §27 (资质审核) + §38 (连带责任)
- 实施：M4-02 渠道商资质年审 (每年) + §M4-16 入口
- 协议中要求渠道商承诺合规、不夸大宣传 / 假冒平台名义

15.9 未成年人保护

- M7-08 KYC 年龄校验
- 对所有终端客户：注册时强制勾选“我承诺为成年人”
- 如产品 toC 触达：青少年模式 / 拒绝未成年访问

15.10 Pre-launch 合规清单

- ☐ 持牌分账方上线运行 ⚠️ BLOCK
 - ☐ ICP 经营许可证拿证 ⚠️ BLOCK
 - ☐ 生成式 AI 服务备案 + 算法备案 ⚠️ BLOCK
 - ☐ 大模型白名单生效 ⚠️ BLOCK
 - ☐ 个人渠道商代扣代缴方案 + 系统嵌入 ⚠️ BLOCK
 - ☐ 全电发票对接 ⚠️ BLOCK
 - ☐ 隐私 / 用户 / 渠道商协议律师定稿
 - ☐ PIA 报告留档
 - ☐ consent_log 上线
 - ☐ KYC 流程：年龄校验 / 加密 / KMS / 冷归档 5 年
 - ☐ CAC 标准合同 (SG 启用前)
 - ☐ 等保 2.0 二级备案
 - ☐ DPO 任命 + 公示
 - ☐ 内容安全双层审核
 - ☐ 违法内容上报通道
 - ☐ 深度合成水印 (如适用)
-

16. 威胁模型 (NEW)

16.1 信任边界



16.2 STRIDE per Component

组件	Spoofing	Tampering	Repudiation	InfoDisclosure	DoS	Elev.
浏览器/UI	钓鱼 → MFA	XSS → CSP nonce	—	XSS → 同上	客户端不护	跨站 → SameSite
TraceNexBiz	JWT 被盗 → 短 TTL + revoke list	DTO 校验	append-only audit_log	日志 PII scrubber	rate-limit per-account	矩阵权限 §3.4
Fy-api API	mTLS + HMAC	HMAC 覆盖 method/path/body	log + idem-key	mTLS 加密 + payload 不含 PII	per-key quota	scoped key
RDS	DB user 强密码 + IP 白名单	应用 user 无 DDL	append-only audit_log	KMS 行级加密敏感字段	连接池上限	最小权限
OSS	IAM 临时凭证	桶版本控制	访问日志	私有桶 + 短 TTL presigned URL	客户端 / 网关限速	桶级策略
KMS	RAM 角色	KMS 不可改	访问审计	KMS 不导出	配额	最小权限 RAM
持牌分账方	API Key + IP	签名	流水	加密	provider SLA	限制 endpoint

16.3 关键 BOLA / IDOR 防御 pattern

```
// middleware/scope.go
type ActorContext struct {
    ActorType string // "partner" | "customer" | "staff" | "system"
    ActorID   int64
    Elevated  bool
    TraceID   string
}

func RequirePartnerScope(repo PartnerRepo) gin.HandlerFunc {
    return func(c *gin.Context) {
        userID := c.GetInt64("fy_user_id") // from Fy-api JWT
        partner, err := repo.FindByFyUserID(c.Request.Context(), userID)
        if err != nil || partner == nil || partner.Status != PartnerStatusActive {
            c.AbortWithStatusJSON(http.StatusForbidden, errorBody(ErrNotPartner))
            return
        }
        c.Set("scope", ActorContext{
            ActorType: "partner", ActorID: partner.ID, TraceID: c.GetString("trace_id"),
        })
        c.Next()
    }
}

func (r *CustomerRepo) FindByID(ctx context.Context, scope ActorContext, id int64) (*Customer, error) {
    q := r.db.WithContext(ctx).Model(&Customer{}).Where("id = ?", id)
    switch scope.ActorType {
    case "partner":
        q = q.Where("partner_id = ?", scope.ActorID)
    case "customer":
        q = q.Where("id = ?", scope.ActorID)
    case "staff":
        if !scope.Elevated { return nil, ErrForbidden }
        r.audit.Record(ctx, scope, "customer.read.elevated", id, nil)
    default:
        return nil, ErrForbidden
    }
    var c Customer
    if err := q.First(&c).Error; err != nil {
        if errors.Is(err, gorm.ErrRecordNotFound) { return nil, ErrNotFound } // 404 不泄露存在
        return nil, fmt.Errorf("customer find: %w", err)
    }
}
```

```
    return &c, nil
}
```

CI 矩阵测试 (强制, 每个读端点):

```
func TestCustomerDetail_BOLA(t *testing.T) {
    a, b := seedTwoPartners(t)
    custOfA := seedCustomer(t, a)
    resp := getAs(t, b.Token, "/api/customer/"+strconv.FormatInt(custOfA.ID, 10))
    require.Equal(t, http.StatusNotFound, resp.Code, "must be 404, never 200/403")
}
```

16.4 输入校验 baseline

- 所有金额 `int64` + `validate:"gt=0,lte=1000000000"`
- markup `decimal.Decimal`, `>= 1.0` 且 `<= max_markup`
- 字符串字段长度限制 (防 DoS) + HTML escape (防 XSS)
- 文件上传 magic byte 校验 + 大小限制 + ClamAV 扫描

16.5 PII 矩阵

字段	分类	加密	保留	法律基础
邮箱	一般 PI	否	注销前	PIPL §13 合同履行
手机号	一般 PI	AES-GCM (KMS 信封)	注销前	合同履行
身份证号	敏感 PI	AES-GCM	5 年 (反洗钱)	法定义务
法人姓名	敏感 PI	AES-GCM	5 年	法定义务
法人身份证图片	敏感 PI	OSS KMS 加密	30d 热 + 5 年冷	法定义务
营业执照	一般 (含敏感)	OSS KMS 加密	30d 热 + 5 年冷	法定义务
支付宝实名	敏感 PI	AES-GCM	5 年	法定义务
银行卡号	敏感 PI	AES-GCM	注销 + 5 年	法定义务
人脸	生物识别	AES-GCM	完成认证后立即清	单独同意

16.6 日志 PII scrubber

```
type LogScrubber struct {}  
func (s *LogScrubber) Hook(e *zerolog.Event, level zerolog.Level, msg string) {  
    // 命名规则: 以 `_pii` 结尾的 field 自动 redact  
    // 模式识别: 身份证 18 位 / 手机号 11 位 / email pattern  
}
```

17. 鉴权与会话 (NEW)

17.1 会话来源

- TraceNexBiz 复用 Fy-api JWT (单一源真理)
- TraceNexBiz 自发的浏览器 cookie: `tnbiz_session`, scope `*.tracenex.cn`, SameSite=Lax, Secure, HttpOnly, 5min idle TTL (staff) / 8h (partner / customer)
- JWT 含 `jti` 字段; 服务端 Redis 维护 revocation list (key `revoked:jti:{id}` TTL = JWT exp)

17.2 MFA 矩阵

角色	TOTP	WebAuthn	强制阈值
super_admin	必	必	永远
operations / finance	必	推荐	永远
support	必	推荐	永远
partner	必	可选	wallet > 0 时强制; wallet = 0 时建议
customer	可选	可选	充值 > ¥1000 时建议

17.3 CSRF

所有 state-changing endpoint (POST/PUT/DELETE/PATCH) 强制: - `Origin` 或 `Referer` header 必须在 allowlist - SameSite=Lax cookie

17.4 密码策略

- min length 12, HIBP k-anonymity API offline 检查
- 登录失败 5 次 → 15 min lockout
- 错误信息统一 (“用户名或密码错误”)

17.5 密码重置

- 邮件 + SMS 双因子 (partner 强制)
- 重置后所有 jti 进入 revocation list

17.6 CORS 白名单

`partner.tracenex.cn`、`api.tracenex.cn`、`*.aitracenex.com` 等明确列举; 不允许 `*`。

17.7 安全 headers

- HSTS (preload)
- CSP (`script-src 'self' 'nonce-...'`)

- X-Frame-Options: DENY
 - Referrer-Policy: strict-origin-when-cross-origin
 - Permissions-Policy: 关闭未用 feature
-

18. 幂等契约 (NEW)

18.1 适用范围

所有 state-changing endpoint (钱包 / 客户额度 / 退款 / 充值 / KYC 提交 / 工单创建 / saga step) 必须接受 `Idempotency-Key` HTTP header。

18.2 Server 行为

```
on receive request:
  1. validate IdemKey UUID format
  2. record_hash = sha256(method + path + canonical(query) + sha256(body))
  3. SELECT idempotency_record WHERE actor_id, idempotency_key, endpoint
     case found AND request_hash == record_hash:
       return cached response
     case found AND request_hash != record_hash:
       return 409 Conflict + "Idempotency-Key reused with different body"
     case not found:
       INSERT pending record
       execute handler
       UPDATE record with response
       return response
  4. record TTL = 24h
```

18.3 跨服务幂等

TraceNexBiz → Fy-api 内部 API 调用, 传同一 `Idempotency-Key`。Fy-api 覆盖层在 `internal_idempotency` 表保留 7 天 (钱包 saga 长 retry 场景)。

18.4 saga_step 配合

- saga_id = idempotency key
- 每个 step 落 saga_step row
- 重启时按 status='in_progress' 续跑

19. 密钥管理 (NEW)

19.1 KMS 选型

Aliyun KMS (与 Fy-api / RDS / OSS 同生态, 最小化运维成本)。

19.2 信封加密

- KEK 在 KMS (不出 KMS)
- DEK 由 KMS 生成, 加密形态 + 明文形态返回; 明文 DEK 在内存 LRU 缓存 1h; 加密形态 DEK 持久化到表行 (`encryption_key_id` 列指向 KEK 版本)
- 加密 / 解密在应用层用明文 DEK 做 AES-GCM

19.3 PII 加密包装

```
type EncryptedString struct {
    plain string `pii:"true" json:"-`      // 序列化时丢弃
    cipher Ciphertext                      // {nonce, encrypted_dek, body, key_id}
}

// GORM custom Marshaler / Unmarshaler
func (e *EncryptedString) Value() (driver.Value, error) { ... }
func (e *EncryptedString) Scan(src any) error { ... }
```

19.4 KEK 轮换

- 每 12 个月手工轮换 KEK
- 旧 KEK 保留供解密历史 DEK, 不再加密新数据
- 后台 batch 任务逐渐重新加密历史敏感字段 (每天 limit + 速率控制)
- 完成后旧 KEK 进入 disabled 状态

19.5 secret 管理

- 应用 secrets (DB 密码、Fy-api HMAC、OSS AK/SK、SMTP、持牌方 API key) 通过 Aliyun KMS Secret Manager 注入
- 不允许 plaintext .env 写仓库
- CI 用 sealed secret

19.6 OSS 私有桶 presigned URL

- $TTL \leq 300s$
- `?response-content-disposition=attachment`

- 不在 URL 中出现 PII；URL 不进日志（log scrubber 过滤 OSS 域名 query string）
-

20. 术语表

术语	含义
TraceNex Partner / TraceNexBiz	本 PRD 描述的渠道分销 SaaS
Fy-api	TraceNex 现有 AI 网关后端
partner / 渠道商	在 TraceNex 上发展自有客户的代理商
customer / 终端客户	通过 partner 接入并调用 API 的最终用户
直营客户	不经 partner、直接和平台签约的用户 (customer.partner_id IS NULL)
席位 / seat / License	一个 seat 绑定一个 Token，按席位计费的销售模式 (v1.x)
group_ratio	Fy-api 中决定计费倍率的字段，per-group 配置
markup	渠道商在批发价上的加价倍率 (v0.2 多维度规则)
wholesale / retail	wholesale = 平台批发价；retail = 客户实际付的价 = wholesale × markup
revenue / cost / payout	revenue = 客户付的钱 (gross)；cost = 渠道商承担的批发成本；payout = 渠道商实得 (revenue – cost – tax – 平台费)
outbox	应用层消息事务表，配合 poller 实现异步可靠投递
saga / hold / commit / release	分布式事务模式术语 (§9.4)
二清	无证支付清算，违法 (§15)
持牌分账方	央行核发支付牌照、可做“分账”业务的机构
PII	个人识别信息 (PIPL 术语：个人信息 / 敏感个人信息)
PIA	个人信息保护影响评估 (PIPL §55)
CAC	国家网信办
KMS	密钥管理服务 (Aliyun KMS)
KYC	Know Your Customer，实名认证
DPO	Data Protection Officer，数据保护负责人 (PIPL §52)
CIIO	关键信息基础设施运营者
JWT / WebAuthn / TOTP	标准鉴权术语
BOLA / IDOR	Broken Object Level Authorization / Insecure Direct Object Reference

术语	含义
ICP 证 vs 备案	“ICP 经营许可证”是经营性资质（强制）；“ICP 备案”是非经营性的（不够）

附录 A：隐私政策草案大纲（初版）

由律师定稿；本节仅是产品要求的章节骨架。

1. 适用范围
 2. 收集的信息
 - 一般 PI / 敏感 PI / 设备 / 行为 分类
 3. 各类信息的目的、法律依据、保存期限
 4. **单独同意场景列表**
 - 人脸 / 身份证号 / 行踪轨迹 / 跨境
 5. 共享 / 委托处理 / 出境（含 SG CAC 标准合同链接）
 6. 用户权利
 - 查阅 / 更正 / 删除 / 撤回同意 / 注销账号 / 投诉
 7. 安全措施（KMS / 最小化 / 内部访问控制）
 8. 未成年人保护
 9. Cookie 与同类技术
 10. 政策变更通知
 11. 联系方式（DPO 邮箱、客服、网信办投诉路径）
-

附录 B：用户协议 / 渠道商合作协议要点

1. 平台、渠道商、客户三方关系定义
 2. 渠道商作为”平台内经营者”的合规承诺
 3. 责任分层（生成内容 / 价格 / 广告 / 客户隐私）
 4. 平台对违规渠道商的处置权（停权 / 扣分润 / 追偿）
 5. 个人渠道商代扣代缴个税授权条款
 6. 内容审核责任（用户对 prompt 负责；平台保留拦截权）
 7. 价格政策（max_markup / 反倾销 / 反价格联盟）
 8. 数据出境同意
 9. 争议解决（仲裁地约定）
 10. 协议变更通知与终止条款
-

附录 C: Fy-api 覆盖层 (overlay) 清单

v0.1 谎称“Fy-api 不动一行代码”。v0.2 接受约 200–300 LOC 的覆盖层。全部为新文件，遵循 `Fy-api/CLAUDE.md` overlay 策略；纳入 `Fy-api/OVERLAY.md` 跟踪；月度上游同步可吸收。

C-1 内部 API 路由 + 鉴权

- `Fy-api/router/api-internal-router.go` (NEW, ~50 LOC): 注册 `/api/internal/*`
- `Fy-api/middleware/internal_auth.go` (NEW, ~80 LOC): HMAC + timestamp + nonce + key-id rotation; mTLS 在网关层强制

C-2 内部 Controllers

- `Fy-api/controller/internal_user.go` (NEW, ~120 LOC): CreateUser / Topup / Deduct / SetGroup / SetGroupRatioOverride / EraseUser
- `Fy-api/controller/internal_token.go` (NEW, ~30 LOC): CreateToken
- `Fy-api/controller/internal_usage.go` (NEW, ~40 LOC): ByUser / ByGroup
- `Fy-api/controller/internal_group.go` (NEW, ~30 LOC): UpsertGroupRatio + Pub/Sub publish
- `Fy-api/controller/internal_idempotency.go` (NEW, ~20 LOC): ByIdemKey 探活

C-3 字段升级

- `Fy-api/migrations/2026_05_xx_widen_quota_to_bigint.sql`:
 - `users.quota` INT → BIGINT
 - `logs.id` INT → BIGINT
 - `logs.quota` INT → BIGINT
 - PG / SQLite 兼容 (migration 脚本三方方言分支)

C-4 GroupRatioOverride

- `Fy-api/model/user.go`: `GroupRatioOverride float64 \ gorm:"default:0"`` (覆盖层 patch)`
- `Fy-api/setting/ratio_setting/group_ratio.go`: `GetEffectiveGroupRatio(user, group)` 检查 override 优先

C-5 Outbox 表 + 同事务写入

- `Fy-api/migrations/2026_05_xx_consume_log_outbox.sql`: 建表 (§8.19)
- `Fy-api/model/log_outbox.go` (NEW, ~40 LOC): 写入函数
- `Fy-api/model/log.go::RecordConsumeLog`: 增加同事务 `outbox.WriteFromLog(log)` 调用 (覆盖层 patch ~5 LOC)

C-6 Pub/Sub + 缩短 SyncFrequency

- `Fy-api/model/option.go::UpdateOption` : 增加 Redis publish (覆盖层 patch ~10 LOC)
- `Fy-api/main.go::startup` : 增加 Redis subscribe goroutine (覆盖层 patch ~30 LOC)
- `common/init.go` : 默认 SyncFrequency 60 → 5 (不强制, 由 biz_setting 控制)

C-7 内部 idempotency 表

- `Fy-api/migrations/2026_05_xx_internal_idempotency.sql` : 内部 API idempotency 持久化
- `Fy-api/model/internal_idempotency.go` (NEW, ~30 LOC)

C-8 OVERLAY.md 条目

`Fy-api/OVERLAY.md` 增加 B-7 ~ B-13 条目, 覆盖以上文件。

C-9 估算

项	LOC	风险
路由 + middleware	130	低
Controllers	240	中 (业务逻辑)
Migration	80	中 (PG/SQLite 兼容)
Model patch	85	低
Pub/Sub	40	低
合计	~575	—

说明: 实际 LOC 略高于”200-300”, 因为 Migration + 测试一起算。**核心 Go 代码** 约 250-300 LOC, 剩余是 SQL + 测试。

附录 D：术语表

见 §20。

附录 E：算法 / 模型备案文本草案骨架（NEW，v1.0 合规要求 NEW-2）

由合规 + 律师定稿；本节仅给出网信办备案系统所要求字段的产品/技术方答案模板。

E.1 备案分类（四类备案，区分主体）

备案类型	法律依据	适用对象	提交主体
生成式 AI 服务提供者备案	《暂行办法》§17	向境内用户提供生成式 AI 服务的运营主体	TraceNex 法人主体（公司）
算法备案	《算法推荐管理规定》§24	含算法推荐 / 路由 / 排序的服务	同上（若启用模型路由排序）
深度合成服务备案	《深度合成管理规定》§19	含图 / 视频 / 音频生成的服务	同上（若上架深度合成模型）
大模型备案核查	网信办大模型备案清单	上架的每个境内服务模型	模型方（白名单）

E.2 提供者备案文本字段

- 服务名称：TraceNex（含 TraceNex Partner 子产品）
- 提供者主体：（公司全称）
- 信息内容功能：聚合多家已备案大模型，向境内用户提供 AI 推理网关与渠道分销服务
- 应用场景：通用 AI 助手 / 知识问答 / 代码辅助 / 商务文案
- 服务对象：企业用户（B 端，KYC 通过）+ 个人付费用户（C 端，实名）
- 技术架构：自有网关 + 上游已备案大模型 + 国产合规审核服务（§7.12）
- 内容安全机制：输入侧关键词 + 国产分类模型审核；输出侧分类拦截；命中违法 24h 上报（§M12-04）
- 数据处理：详见隐私政策（附录 A）
- 应急响应：DPO + 安全负责人；24h 工单响应；24h 违法内容上报 SLA

E.3 算法备案文本字段（若启用排序/路由）

- 算法名称：TraceNex 模型路由 / 渠道分发算法
- 算法机制：根据上游渠道权重 + 健康度 + 价格做模型/渠道选择；不对用户内容做个性化排序
- 应用场景：选择上游 AI 服务通道
- 数据来源：用户请求元信息（modal、token 数）+ 渠道健康度数据
- 决策依据：成功率、延迟、单价的加权组合
- 用户控制：用户可在客户后台禁用/启用单个模型

E.4 上报通道字段（M12-04 详化）

上报对象	时机	通道	字段
12377（网信办举报中心）	命中违法 24h 内	API + 留档	user_id（脱敏） / prompt_hash / 模型 / 命中类目 / 处置动作 / 时间戳
属地公安网安	命中疑似刑事违法 24h 内	邮件 + 备案号	同上 + 联系信息
内部留档	命中即发生	audit_log	全字段，加密存 5 年（按反洗钱标准）

21. v1.0 CHANGELOG (相对 v0.2)

本节记录 v0.2 → v1.0 在 4 agent Round-2 review 后合入的 mechanical diffs。详见各 reviewer report: </Users/nathan/Projects/apiGateway/TraceNexBiz/reviews/round-2/>

21.1 PM review diffs (合入)

来自	处理
MEDIUM-3: §13 Q6 vs §4.10 内部不一致	§4.10 “客户主动 7 日内” 替换为 “客户主动 <code>{refund_window_days}</code> 日内”; Q6 保留 BLOCK 状态
MEDIUM-5: Phase 1 partner 初始余额 provenance	§12.1 增 footnote: “初始余额 = <code>partner_wallet_log</code> (type=‘adjustment’, OperatorType=‘platform_staff’, Operator=finance) 行; 不存在隐式拨付路径”
MEDIUM-6: §14.2 vs §4.17 删除生效时间不一致	统一为: 用户提交删除请求 → 平台核身 (最长 5 天) → <code>customer.deleted_at = NOW()</code> ; §14.2 注明 “5d 核身窗口可缩短”
MEDIUM-7: system actor 在 §3.4 缺失	§3.4 加注: <code>system</code> 行隐式存在; <code>audit_log.ActorType=‘system’, ActorId=0</code> (cron) / 1 (outbox poller) / 2 (saga retry) 等保留位
MEDIUM-8: §17.2 partner MFA 阈值	改为”KYC 通过即强制” (合 Security HIGH-R2-3)
LOW-2: 术语表重复	附录 D 改为单引用 §20
HIGH-1/2/3: 跟踪到 §22 follow-ups	v1.0 不阻塞, Phase 1 实施期解决

21.2 Architect review diffs (合入)

来自	处理
附录 C-3: BIGINT 三方策略	C-3 重写: MySQL 用 <code>MODIFY ... BIGINT</code> ; PG 用 <code>ALTER COLUMN ... TYPE BIGINT</code> 并标注 PG <12 全表重写成本; SQLite 因 INTEGER 类型亲和已是 8 字节 → no-op, guard <code>if !common.UsingSQLite { ... }</code> ; migration 顺序: 先升 Fy-api <code>users.quota</code> / <code>logs.id</code> / <code>logs.quota</code> , 再启用 TraceNexBiz <code>revenue_log.fy_api_log_id</code> 写入
§M5-01 cron lock 选型	锁定决定: Phase 1 用 Redis SETNX + 续约 goroutine + <code>settlement_run.lease_expires_at</code> ; K8s Lease 等 ops topology (Q11+ 决定) 落地后 Phase 2 评估切换
§9.3 outbox consumer 状态机	§8.19 <code>consume_log_outbox</code> 加字段: <code>status</code> enum('pending','consumed','failed','dead_letter')、 <code>retry_count</code> int、 <code>last_error</code> text、 <code>trace_id</code> varchar(64); 多 poller 用 <code>SELECT ... FOR UPDATE SKIP LOCKED</code> (合 Security M-R2-4); 消费后 <code>DELETE</code> 而非 <code>UPDATE</code> (避免索引 churn); <code>dead_letter</code> 触发 ops alert
§17.1 JWT/session 关系	§17.1 重写: Fy-api JWT 是单一鉴权令牌; <code>tnbiz_session</code> cookie 仅做 CSRF 防御 + UI 引导, 不用于鉴权; JWT revocation list 由 Fy-api Redis 维护, TraceNexBiz 共享同一 Redis 实例的 <code>revoked:jti:*</code> keyspace
§6.3 GRANT 例子	§6.3 加示例 SQL (详见正文)
§8.13 audit_log 哈希链并发	跟踪到 §22 follow-ups (Security HIGH-R2-1)
各 NEW LOW (saga TTL / trace_id / mTLS query 串)	详见正文

21.3 Security review diffs (合入)

来自	处理
HIGH-R2-1 audit log 并发	§22 follow-ups
HIGH-R2-2 saga 卡死无升级	§14.6 saga 加 <code>escalated</code> 状态; <code>saga_step.attempts</code> 上限 + ops 工单
HIGH-R2-3 partner MFA 时机	合并到 PM MEDIUM-8, §17.2 已改
M-R2-1 Elevated 设置机制	§3.4 加注: staff <code>Elevated=true</code> 仅通过 step-up MFA 单次授权 (≤ 15 min), 不在 session 中持久
M-R2-2 内部 API key 轮换 runbook	§11 加 R-26: HMAC key rotation runbook (N+1 keys, 7 天 overlap, audit usage = 0 后停旧)
M-R2-3 Redis Pub/Sub ACL	§11 加 R-27: Redis AUTH + ACL + 仅内网访问; <code>option_update</code> 频道 publisher = <code>fy_api_writer</code> 身份
M-R2-4 outbox 多 poller	已并入 Architect §9.3 重写
M-R2-5 by-idem-key 调用范围	§6.1 加注: “ <code>GET /api/internal/topup/by-idem-key</code> 仅原始提交者的 <code>X-Auth-KeyId</code> 可调用”
LOW 全部	§11 备查
8 项 Phase 1 acceptance gates	进入 §22 follow-ups

21.4 Compliance review diffs (合入)

来自	处理
NEW-1 ICP 前置条件	§15.1 ICP 行加 footnote (详见正文); §13 Q11 拆为 4 子问题: Q11.1 (注册资本 100 万实缴) / Q11.2 (1 年经营) / Q11.3 (30 万社保) / Q11.4 (已办 ICP 备案)
NEW-2 算法 / 模型备案操作化	§M12-04 改写为含 SLA + 字段 (详见正文); §M12-06 区分四类备案; 新增附录 E (算法/模型备案文本草案骨架)
NEW-3 Cookie + DPO + 用户权利中心	新增 §7.13 PIPL 用户权利中心模块 (M13-01~05); §11 加 R-28; 附录 A 第 9 章对应到产品
NEW-4 Pub/Sub / outbox region 归属	§15.7 跨境数据章节加: “Redis / outbox 实例必须 region-isolated; CN ↔ SG 不允许跨实例订阅 / 复制; 跨实例数据流动须经 DPO 审批 + CAC 备案”
NEW-5 反洗钱 STR	POST_LAUNCH, §22 follow-ups (v1.0 上线 6 月后 review)
BLOCK #1 残留: mchid ISV	§7.6 加: “平台 mchid 仅作为 ISV 服务商身份的佣金接收主体, 不作为客户付款收款方”
§3.1 渠道商电商法身份	§3.1 加: “法律身份:《电商法》§9 平台内经营者; TraceNex 承担 §27 / §38 责任”
§8.18 consent_log 字段	§8.18 字段已完整

21.5 verdict 收敛矩阵

Round	PM	Architect	Security	Compliance	行动
Round-1 (v0.1)	NEEDS_REVISION (5C/9H)	NEEDS_REVISION (5C/6H)	BLOCK (7C/6H/10M)	BLOCK (4 BL/8 PL)	→ v0.2 重写
Round-2 (v0.2)	ACCEPT_WITH_NOTES (0C/3H)	ACCEPT_WITH_NOTES (0C/3H)	ACCEPT_AS_V1.0 (0C/3H)	ACCEPT_WITH_NOTES (0 BL/3 PL)	→ v1.0

22. v1.0 → Phase 1 follow-ups (NEW)

以下事项**不阻塞**v1.0 文档定稿，但 Phase 1 验收前必须解决，Phase 2 hard-gate 前必须落地。这些条目从 PRD 迭代退役，进入 Phase 1 工程任务列表。

22.1 Phase 1 实施期 HIGH (≤ Phase 1 验收)

ID	来自	主题	责任	截止
F-1	PM HIGH-1	per-model markup 执行路径决策 (扩展 §C-4 vs 推迟 v1.x)	架构	Week 1
F-2	PM HIGH-2	settled-and-paid 退款产生的 partner debt 模型 (partner_debt 表 vs 负 balance + 阈值自动暂停)	架构 + 财务	Week 2
F-3	PM HIGH-3	客户充值 saga 详细规约 (M2-03 持牌方 → Fy-api topup)	架构	Week 3
F-4	Architect HIGH-A1	BIGINT 三方言 migration 实施	工程 + 运维	Week 1 (Fy-api 覆盖层 PR)
F-5	Architect HIGH-A2	cron lock: Redis SETNX + 续约 goroutine (Phase 1); K8s Lease 评估 (Phase 2)	工程	Week 4
F-6	Architect HIGH-A3	outbox consumer 状态机实现 (status / retry / dead-letter / leader)	工程	Week 4
F-7	Security HIGH-R2-1	audit_log 哈希链并发模型决定 (per-shard chain / chain_position UNIQUE / 异步 signer)	安全 + DB	Week 4 (audit_log 上线前)
F-8	Security HIGH-R2-2	saga fy_topup_unknown → escalated 状态 + max_attempts + ops runbook	工程	Week 4
F-9	Security HIGH-R2-3	MFA 触发条件改为 “KYC 通过即强制”	工程	Week 3
F-10	Architect-2 H-1	outbox 表必须建在 LOG_DB (与 logs 同库 / 同事务); tnbiz_app 在 LOG_DB 上需 SELECT/UPDATE/DELETE on consume_log_outbox	工程 + 运维	Week 1 (覆盖层 PR)
F-11	Architect-2 H-3	BIGINT 升级列清单完整: 除 users.quota / logs.id / logs.quota 外, 还需评估 users.used_quota / users.request_count / users.aff_quota / users.aff_history_quota ; SQLite 由于无 ALTER COLUMN 走重建表的 migration 路径 (参考 Fy-api/CLAUDE.md Rule 2 + model/main.go:508)	工程 + DB	Week 2

ID	来自	主题	责任	截止
F-12	Architect-2 §C-5	<code>RecordConsumeLog</code> 改造为同事务写入 outbox；现状非事务，需 ~25 LOC 而非 5 LOC（修正 §C-9 LOC 估算）	工程	Week 2
F-13	Architect-2 §C-6	SyncFrequency 切换走 <code>biz_setting.sync_freq_seconds</code> 启动注入，不改 <code>common/init.go</code> 默认值（避免月度 sync 冲突）	工程	Week 1
F-14	Architect-2 OVERLAY 编号	<code>Fy-api/OVERLAY.md</code> 新条目从 B-8 起编号 （B-7 已被 channel-benchmark 占用）	工程	Week 1

22.2 Phase 1 安全验收 gates（Security 要求的 8 项）

ID	主题	验证方式
S-1	F-7 完成 + audit_log 上线	并发压测 + 哈希链一致性校验
S-2	F-8 完成 + 卡死 saga 可被 staff 解锁	回归测试
S-3	F-9 完成	测试 partner KYC pass + 检查 MFA 强制
S-4	Staff <code>Elevated</code> step-up MFA 实现	测试不带 step-up 时被拒
S-5	outbox <code>SKIP LOCKED</code> / 单 leader	多 poller 压测无重复消费
S-6	CI BOLA 矩阵测试 wired in	merge gate；§3.4 每行 × 列均覆盖
S-7	CI invariant：app DB user 无 <code>audit_log.UPDATE/DELETE</code>	<code>SHOW GRANTS</code> CI 检查
S-8	CI invariant：所有 <code>Encrypted*</code> 字段含 <code>json:"-"</code>	go AST check

22.3 Phase 2 hard-gate (Compliance 必跨)

ID	主题
C-1	ICP 经营许可证拿证
C-2	生成式 AI 服务提供者备案 + 算法备案核准
C-3	持牌分账方上线运行 (含 mchid ISV 路径)
C-4	个税代扣系统嵌入 + 跑通一次月结
C-5	全电发票打通
C-6	PIA 报告留档
C-7	等保 2.0 二级备案
C-8	DPO 任命公示 + 用户权利中心 §7.13 上线
C-9	内容安全双层审核 + 12377 上报通道闭环

22.4 上线后监控 (POST_LAUNCH / MONITOR)

ID	主题	触发
M-1	CIIO 认定监控	用户量 / PII 量到一定规模
M-2	反洗钱 STR 流程评估	上线 6 月或被监管约谈
M-3	SG PDPA 合规 (DPO 任命 + 数据泄露 72h 通知)	SG 启用前
M-4	广告法极限词	v1.2 加入 “渠道商话术合规检查”

本文档为 **v1.0**。Round-2 四方 review 全部通过；CRITICAL = 0、HIGH ≤ 3。Phase 1 工程立即启动；后续 v1.x 增量在 Phase 2A kickoff 前以 v1.0.1 patch 形式合入 §22.1 F-1/F-2/F-3 三项决策。